ABSTRACT

Title of dissertation: REGULATE, RECOVER, REPEAT: MULTISTAKEHOLDER CONFLICT ANALYSIS FOR SOFTWARE CYBERSECURITY

Elliot Talbert-Goldstein, Doctor of Philosophy, 2026

Dissertation directed by: Professor Carolyn Seaman
University of Maryland, Baltimore County
Department of Information Systems
Empirical and Applied Software Engineering Lab (EASEL)

A secure cyberspace is required for all private and public enterprises to function properly, and for individuals to contribute to the commercial and democratic interests of society. The field of software engineering plays a critical role in ensuring this security. However, there are major conflicts that inhibit success, and there is a great need for cooperation to improve it. Software engineering professionals and researchers can observe the world around them, and use scientific methods to help create new tools and processes to address the security needs of users, governments, and software producers. However, no prior research investigates the systems of conflict and cooperation that ensure or inhibit software security among intergovernmental, national, subnational, industrial/commercial, and interpersonal actors. The interactions between these members of society govern the security of cyberspace. Research to support successful cooperation requires interdisciplinary study through fields including software engineering, conflict analysis, information systems, political science, cyber security, and management science. I will analyze cases of social

conflicts inherent to engineering software security to construct a novel grounded theory that illustrates the factors that contribute to conflict, the efforts to manage them, and the impacts on stakeholders. Using the results of this empirical analysis, stakeholders will better be able to cooperate and establish frameworks, methods, and tools to support the security needs of nations, enterprises, and people. Software engineering practitioners and researchers will be able to use the resulting theory to solve problems related to national security, corporate commercial interests, and individual human rights.

This research will use qualitative research methods to study existing cases and create a grounded theory of the impacts of conflict and collaboration on software security at a large scale. The goal is to apply this novel theory to identify opportunities to manage conflict, create cooperation, and build capacity for software security with stakeholders, partners, and allies, even when power is asymmetric. As software engineering professionals and researchers, we must be able to interpret and address conflict that could result in negative externalities to users, constituents, teams, companies, governments, and international organizations. Furthermore, we should be able to contribute to cooperation, and the healthy management of conflict, according to our needs and the needs of our stakeholders. For the software security professional, including engineers, regulators, researchers, and leaders, there is actionable knowledge derived from this dissertation that can be put to use to investigate both past and unfolding conflicts.

REGULATE, RECOVER, REPEAT: MULTISTAKEHOLDER CONFLICT ANALYSIS FOR SOFTWARE CYBERSECURITY

by

Elliot Talbert-Goldstein

Dissertation proposal submitted to the Faculty of the Graduate School of the
University of Maryland, Baltimore County in partial fulfillment
of the requirements for the degree of
Doctor of Philosophy
2026

Advisory Committee:
Professor Carolyn Seaman, Chair/Advisor
Professor Anita Komlodi
Professor Brian Polkinghorn
Professor Sreedevi Sampath
Professor Yaxing Yao

© Copyright by
Elliot Talbert-Goldstein
2026

Acknowledgments

I want to thank my wife, Susan, and family, Robin, Bruce, and Benjamin, for preparing me with the skills and knowledge I needed for this project, and the patience to see me through it. I want to thank my advisor, Carolyn Seaman, first for her commitment to generations of people through her admirable work, and second for supporting my effort to contribute something meaningful to our field. I also need to thank the interdisciplinary stakeholders that helped me along the way including friends, teachers and colleagues, especially Udi Sommer, Donald Snyder, Aaron Massey, Julie Gilless, Theresa Mabe, Dennise Cardona, Ted Murphree, as well as Rick Gershberg and the crew of *Momentous*. Thanks also to my committee for taking the time and energy to review and for your input along the way.

Table of Contents

Acknowledgements ii

1 Introduction 1

2 Background 6
- 2.1 Definitions of Conflict & Cooperation . . . 6
  - 2.1.1 Conflict . . . 6
  - 2.1.2 Cooperation . . . 8
- 2.2 Defining Software Security, Cybersecurity, Data Security, & Privacy . . . 10
- 2.3 Establishing Context: Enumerating the Stakeholders . . . 12
  - 2.3.1 Regulators . . . 12
  - 2.3.2 Software Producers . . . 14
  - 2.3.3 Users . . . 15
- 2.4 Existing Models, Methods, & Frameworks for Analysis . . . 16
  - 2.4.1 Conflict Analysis . . . 17
  - 2.4.2 Software Engineering Research . . . 18
  - 2.4.3 Management & Policy . . . 20
  - 2.4.4 Regulatory Compliance . . . 22
  - 2.4.5 International Relations . . . 23
  - 2.4.6 Theoretical Frameworks . . . 25

3 Methodology & Approach 28
- 3.1 Grounded Theory Approach . . . 29
  - 3.1.1 Basic Stage . . . 31
  - 3.1.2 Baseline Model . . . 33
    - Node Details . . . 35
  - 3.1.3 Advanced Stage Theory Development . . . 37
- 3.2 Case Selection . . . 40
- 3.3 Data Collection Protocol . . . 41
  - 3.3.1 Field Research . . . 41
  - 3.3.2 Secondary Data . . . 43

3.4 Threats to Validity . . . 45
3.4.1 Construct Validity . . . 46
3.4.2 Internal Validity . . . 47
3.4.3 External Validity . . . 49
3.4.4 Reliability . . . 50

4 Case Data and Analysis 51
4.1 Illuminate Education . . . 51
4.2 International Committee of the Red Cross . . . 54
4.3 Equifax . . . 57
4.4 CatalanGate . . . 60
4.5 Office of Personnel Management . . . 63

5 Grounded Theory 66
5.1 The Model . . . 67
5.1.1 Final Model . . . 68
5.1.2 Model Components . . . 71
5.2 The Theory: Regulate, Recover, Repeat . . . 77
5.3 Findings . . . 78
5.4 Finding 1: Regulatory Context Drives Compliance After Incidents . . . 79
5.4.1 Context & Environments . . . 79
Threat Environment . . . 80
Regulatory Environment . . . 80
5.4.2 Compliance Behaviors . . . 82
Antecedent Operating Compliance . . . 82
Response Compliance Behaviors . . . 83
5.4.3 Finding . . . 84
5.4.4 Testing the Theory . . . 84
5.5 Finding 2: Regulatory Operations Impact User Outcomes . . . 85
5.5.1 Stronger Regulatory Operational Environments . . . 86
5.5.2 Weaker Regulatory Operational Environment . . . 88
5.5.3 Impacts on User Outcomes . . . 88
Favorable User Remedies & High Regulator Costs . . . 89
Unfavorable Remedies & Low Regulator Costs . . . 89
5.5.4 Finding . . . 90
5.5.5 Testing the Theory . . . 90
5.6 Finding 3: Capacity Does Limit User Response, Remediation, and Recovery 91
5.6.1 Precursor Capacity . . . 91
Responses . . . 92
Finding . . . 92
5.6.2 Testing the Theory . . . 93
5.7 Finding 4: User Responses Impact Costs, but not Necessarily Remedies . . 94

5.7.1 Active Posturing & Compensating Response 94
Outcome Costs and Remedies 94
5.7.2 Note: Passive Posturing & Compensating Response 96
5.7.3 Finding 96
5.7.4 Testing the Theory 97
5.8 Finding 5: Correcting Activities and Their Outcomes 97
5.8.1 Favorable User Remedies 98
5.8.2 Less Favorable User Remedies 99
5.8.3 Transformation as an Outcome 100
5.8.4 Favorable User Remedies 101
5.8.5 Finding 102
5.8.6 Testing the Theory 102
5.9 Finding 6: Regulator Precursors were a Determinant of their Responses and Outcomes 103
5.9.1 Stricter Regimes and Strong Capacity 103
5.9.2 Weak Capacity and Somewhat Active Rulemaking 104
5.9.3 Finding 105
5.9.4 Testing the Theory 105

6 Discussion 106
6.1 RQ1: What are the types of conflicts that occur between stakeholders related to software security? 106
6.2 RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security? 108
6.3 RQ3: How can cooperation between these stakeholders be facilitated? . . . 111
6.4 Relationship to the Literature 114
6.5 Limitations 116
6.5.1 Case Selection 117
6.5.2 Methods 118
6.5.3 On Being WEIRD 121

7 Conclusion 123

Bibliography 125

Chapter 1: Introduction

A secure cyberspace is required for all private and public enterprises to function properly, and for individuals to contribute to the commercial and democratic interests of society. The field of software engineering plays a critical role in ensuring this security. There are major conflicts that inhibit this security, and there is a great need for cooperation to improve it. Software security professionals and researchers can observe the world around them, and use scientific methods to help create new tools and processes to address the security needs of users, governments, and software producers. However, no prior research investigates the systems of conflict and cooperation that ensure or inhibit software security, amongst intergovernmental, national, subnational, industrial/commercial, and interpersonal actors. The interactions between these members of society govern the security of cyberspace. Research to support successful cooperation requires interdisciplinary study through fields including software engineering, conflict analysis, information systems, political science, cyber security, and management science.

The goal of this dissertation is to discover methods to analyze and act on conflict in intergroup situations where software security, data protection, and data privacy are concerned. I will analyze cases of social conflicts inherent to engineering software security to construct a novel grounded theory that illustrates the factors that contribute to conflict, the efforts to manage them, and the impacts on stakeholders. Using the results of this empirical analysis, stakeholders will better be able to cooperate and establish frameworks, methods, and tools to support the security needs of nations, enterprises, and people. Soft-

ware engineering (SWE) practitioners and researchers will be able to use this research to solve problems related to national security, corporate commercial interests, and individual human rights.

In order to reach these goals I will address the following research questions:

RQ1: What are the types of conflicts that occur between stakeholders related to software security?

RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security?

RQ3: How can cooperation between these stakeholders be facilitated?

The progression of these research questions matches the intended progression of the research. By choosing cases that can be coded to develop a theory in RQ1 and RQ2, I can identify the conflicts that end in cooperation and those that do not. By studying the differences between these cases, I will be able to address RQ3 in supporting the facilitation of more cooperative outcomes.

In any field conflict is a given. It is necessary, it is normal, and when addressed appropriately, it is healthy [44]. Unfortunately, conflicts can also be complex, intractable, and even "wicked" [24] leading to harms to individuals and societies [74]. Cooperation is the counterpart to conflict; it is both the ideal end result and a preventative measure. Of course, it is not always easy to leverage conflict and move towards cooperation. Social conflict that arises between stakeholders in cybersecurity, whether with a SWE team, agency, or regulator, can lead to less-secure software that violates rights or fails users. By inadequately involving groups of stakeholders in software development, these failures can contribute to broad conflicts in society.

As a software engineering practitioner and researcher, I intend for this research to be empirical and applied in the interest of data security and privacy practices implemented by

stakeholder groups including users, managers, software producers, firms, and governments. As practitioners, it behooves us to understand our place in the conflict and cooperation that exist between these stakeholder groups, because we never know how they could result in unexpected problems and externalities. As researchers, we can meaningfully contribute to the field to benefit stakeholders by advancing the knowledge and practice of engineering software, including organizational and global conflicts. Empirical research should observe the real world and provide valuable knowledge that can be applied to a domain. It can, however, be difficult to conduct and apply research that covers multiple domains and disparate groups of actors. Nevertheless, the field of conflict analysis does just this, and can be applied in multidisciplinary and interdisciplinary ways. My research will bring together different research areas, with a focus on the cybersecurity domain, in order to advance software security research and practice.

In practice, helping people and teams think through conflict and cooperation can be difficult, no matter the situation or scale. For example, during software projects, conflicts can be categorized as personal, task, and process conflicts, leading to faults, failures, and quality problems [44, 49, 99]. Or, in the broadest possible sense, societal conflicts like "wicked problems," typified by large-scale, complex issues, are difficult to address even by extremely capable, well-resourced organizations [24]. Even when we try interventions to manage conflicts, and create new tools to help solve problems, these can also lead to new issues that then need to be addressed. The immediate task of managing organizational conflict and considering negative externalities can be daunting, but taking into consideration the possible impacts on broader social issues is near impossible. Still, it is important that software engineers, professionals, and firms consider the broad context in which they operate. My goal is to give software professionals practical resources to use to consider how they approach their work with their immediate stakeholders, and with the world at large, to help ensure software security. My work should also provide researchers with empirical

data to contribute to further study of software engineering and security.

This research will use qualitative research methods to study existing cases and create a grounded theory of the impacts of conflict and collaboration on software security at micro and macro scales. The goal is to apply this novel theory to identify opportunities to manage conflict, create cooperation, and build capacity for software security with stakeholders, partners, and allies, even when there is asymmetric power. As software engineering professionals and researchers, we must be able to interpret and address conflict that could result in negative externalities to users, constituents, teams, companies, governments, and international organizations. Furthermore, we should be able to contribute to cooperation, and the healthy management of conflict, according to our needs and the needs of our stakeholders. For the software security professional, including engineers, regulators, researchers, and leaders, there should be actionable knowledge derived from this dissertation.

This research began with an extensive multidisciplinary literature review. Based on this literature, I was able to create a baseline model that was used to initiate the research by establishing the coding scheme. I used this preliminary coding scheme to retrospectively study existing cases by collecting data through field research including interviews with subject matter experts. I also collected secondary data such as software artifacts, legal documents, academic data sets, and journalistic sources. I used grounded theory methodologies to analyze the data, including multiple rounds of coding. The end result is a grounded theory of conflict and cooperation related to engineering software security.

This dissertation includes the Background (Chapter 2) using literature to provide key definitions (Sections 2.1 and 2.2), Establishing Context Across Multiple Levels of Society (2.3), and Existing Models, Methods, and Frameworks from relevant fields (2.4). Next, the Methodology & Approach (Chapter 3) section covers my Grounded Theory Approach, Data Collection, Data Analysis, and Threats to Validity. Overviews of the case analyses are included in Chapter 4, and the full versions are available as appendices. In Chapter 5

I describe the final model, as well as the theory and its major findings. Chapter 6 is the Discussion of my results, followed by my Conclusion.

Chapter 2: Background

The following background will cover the multidisciplinary concepts that will inform this research. This will include broad definitions of key terms, prerequisite concepts for studying broad social conflict in cyber security, and existing models in the relevant fields of study. These concepts helped construct the baseline model discussed in Chapter 3.

2.1 Definitions of Conflict & Cooperation

Foundational to this research are concepts of conflict and cooperation. These concepts, studied empirically, help coalesce the multiple disciplines so that they can be investigated harmoniously. Conflict and cooperation can mean different things in different contexts, so this research will focus on the study of social and intergroup conflict as it pertains to data security and privacy.

2.1.1 Conflict

A conflict exists when at least one party believes that their goals are incompatible with those of another party [17, 30]. Such incompatibility can be real or only perceived. The term social conflict focuses on aggregate groups of people, not individuals, and further restricts the definition to exclude "differences of opinion concerning facts and arguments over the interpretation of objective reality" [74]. The aim of this dissertation is to analyze cases of intergroup conflict regarding software security, data protection, and data privacy.

To meet this goal, I will incorporate aspects of social conflict described in foundational academic work and empirical studies of cyber conflict in software engineering.

When we use the term conflict in the software engineering domain, it invokes a lot of ideas and scenarios, all of which are important. At the lowest level is implementation conflict, for example when computing and information technology requirements are not reconciled with expressions for software design or functionality. This could be manifested and observed formally through testing, requirements documentation, knowledge representation, or from user feedback. At the intra-organizational level, team conflict can arise from task, process, or relationship disagreements [44] due to anything ranging from challenging workloads, to cross-cultural issues on global teams, to pair programming dialectics. Between organizations, enterprises may disagree on protocols and best practices to bring consumer and commercial products to market. Broadening to cyberspace, conflict can arise from crime, hackers, espionage, and warfare, with responses depending on the target and the relative scale of the conflict or attack. At the international level, nations can disagree on issues like technical protocols and legal regulations. For individuals, conflict can be with a software service they use or a government agency meant to protect their digital identity; it can be with another user on the web; it can be with a local business or a multinational conglomerate; individual employees can be in conflict with employers. Users' human rights, such as privacy, can even be compromised when security is not engineered effectively. Conflicts in software security can manifest at any one of these points, affecting any and all stakeholders, so they must be kept in consideration.

In software engineering research, we can critically study conflict in software engineering by investigating power dynamics and systemic or institutional problems that are exacerbated, and even created, through software production. Below are some examples of issues related to software business and engineering that intersect with civil and social issues, and may require critical study for resolution. Gender conflict is an issue in software

engineering, as women and gender minorities may suffer from under-representation and discrimination in the field, sometimes leading to software products that do not adequately serve the needs of people of all genders. Disruptive innovation, where a software producer aims to tear down an existing commercial model, creates conflict with existing enterprises, and can introduce new societal issues. For example, starting with Napster in 1999, companies like Spotify launched in 2006, and Hulu and Netflix in 2007 challenging the media industry's traditional structures to give people more control over their consumption of content. Algorithmic justice is a critical approach to challenging mathematical models that can result in disenfranchisement and alienation of people from individual liberties like property and privacy. In the realm of political conflict, software producers can contribute to, or fail to prevent, manipulation of people during times of political turmoil. These are issues in software development where the conditions leading to conflict are asymmetries of power, and the net result can lead to a lack of security.

Across different levels of society, individuals, enterprises, and governments can be embroiled in cyber conflict, from persistent low-level engagements up to explosive harm to critical infrastructure. Power imbalances between parties at each level can vary widely depending on the dispute at hand. Failure to address those inequities can lead to failures in meeting software security goals.

2.1.2 Cooperation

We can concurrently examine cooperation empirically in software security. Cooperation in software security could be considered to be achieved when the stakeholders believe that their privacy and data security needs are in alignment. At the software implementation stage, conflicts are reconciled between heterogeneous stakeholder requirements, although this can be difficult with market-driven requirements [48]. On teams, managers can man-

age conflicts effectively, which is healthy for team formation, and can lead to positive outcomes [44, 73]. In cyberspace we hope our government and private enterprises can protect us from threats and compensate us when issues arise. Nations, along with regulators and technical-legal experts, can implement best practices to create agreements on software interoperability and data privacy, such as via the World Wide Web and Europe's General Data Protection Regulation (GDPR). For individuals, software services can provide support for their customers, such as transaction dispute resolution, content moderation, or simply incorporating their feedback.

Applying cooperation in critical research approaches to software engineering can be a bit more bleeding edge, and requires creative approaches. Turning to the conflict examples presented in the previous section, one area that should not need to be particularly innovative is gender conflict: balancing the contributions of women and gender minorities in software engineering, and removing bias as an obstacle to their participation is not a new idea, though still needed. Ensuring their, and others', access to software, including usability and data privacy, also has room for improvement [6, 36]. With regard to cooperation and "disruption," it took the media industry some time to adapt to the user preference for quick and easy consumption of music and movies over the internet. While Napster initiated this broad conflict, more recently, major media conglomerates have also launched their own streaming services like Disney+, Paramount+, Peacock (NBC Universal), and others to meet the needs of consumers. Algorithmic justice advocates, like the Algorithmic Justice League, attempt to investigate issues [2] like those highlighted by Cathy O'Neill (author of *Weapons of Math Destruction* [69]) to buck historical racist and discriminatory economic practices to protect consumers. Groups like the Electronic Frontier Foundation (EFF) try to protect privacy in an age of regulatory capture and the overturning of *Roe v. Wade* [72]. Challenging monolithic social media, which can undermine democracy and contribute to abuses [41, 47], requires novel approaches and nuanced understanding of how

such complex firms operate and how threat actors take advantage of their software.

Demonstrating the outcomes of cooperation may be easier than showing the possible spectrum of conflict: it is easier to see that a puzzle is complete than it is to organize the pieces. Like the cover of the puzzle box, it is very helpful to have the end result right in front of you to help guide your decisions. My goal will be to provide a useful structure of applicable conflicts, and demonstrate some measures and examples of success, so that practitioners can apply them.

2.2 Defining Software Security, Cybersecurity, Data Security, & Privacy

Ultimately the scope of this study is narrowed to conflict and cooperation specifically as it relates to software security. This allows us to examine a field of inquiry that is rife with challenges and opportunities that need to be addressed, and begs for established methodologies to help resolve them. Below I will define some of the terms that get most often used in this research. While the definitions can be inductively constructed more thoroughly, the following brief explanations should serve to disambiguate them for the purposes of this research.

The IEEE defines software security as "engineering software so that it continues to function correctly under malicious attack" [59]. IEEE goes on to incorporate longitudinal aspects of "building security in" including security requirements engineering and designing for security. This definition focuses on the software producer as the key actor in ensuring that software is secure to protect its users. For the purposes of this research, this surface-level explanation does not need to include the extensive security principles and practices that exist in the business of software engineering.

Cybersecurity, defined by Stevens in [98] refers to "protecting and defending society and its essential information infrastructures, but also a way of prosecuting national and

international policies through information-technological means." By definition, cybersecurity comprises discord between actors such as users, software developers, threat actors, and even regulators who may have misaligned goals as to how to approach the matter. It is a space that requires constant vigilance to plan and execute collaboration. With this definition of cybersecurity in mind, in this research we can consider cyberspace as the physical and digital domains where conflict and cooperation may occur.

Data security is the practice of protecting data from malicious actions while keeping it exposed to those who have permissions to access it. The focus on confidentiality, integrity, and availability, (known as the CIA triad), is frequently used to describe the core concepts of data security. The CIA triad refers to prevention of unauthorized viewing of data, unauthorized modification of data, and unauthorized changing of permissions of authorized users [78].

Privacy refers to how people manage access to their personal information. Privacy management is "dynamic and multidimensional" which means that as situations and information change, people make different decisions about when and how to share their information [71]. While privacy decisions can be made in a variety of contexts [71, 84], our focus will be on privacy in the presence of software security.

To conclude these definitions, we can say that the focus of this research will be on the conflict and cooperation necessary in the practice of engineering software security, in order to broadly promote cybersecurity, which supports stakeholders' data security and privacy. While these concepts could be constructed with more nuance and depth, they are sufficient to support this research.

2.3 Establishing Context: Enumerating the Stakeholders

In this section, I will outline the context for studying cases of social conflict in cyberspace, specifically the groups of stakeholders pertinent to the cases I will analyze in this work. These groups of stakeholders are rooted in different levels of society, based on typical, comparative differences in power, where governments have the most power, enterprises have substantial power, and users have the least power. While somewhat prescriptive, these levels are not strict, and the interplay between stakeholders at each level, as well as their actual power in the real world, leaves this framework open for interpretation. Certainly, we can think of conflicts where individuals are strong and enterprises are weak, or where enterprises are strong and governments are weak. The following categorization of stakeholders is based on literature to structure my grounded theory study.

2.3.1 Regulators

Controlling the most power in most social conflicts are governments. National governments maintain a "monopoly on the legal use of force," according to Max Weber [97], and can therefore wield it in cyber conflict. International conflict can lead to some of the most detrimental consequences in cyberspace, such as through cyber warfare where human life can be affected [18]. Governments are also tasked with leading the development of policy, laws, regulations, and standards that protect their country's citizens and companies. The data security and privacy efforts of a national government have widespread impacts on the functioning of their society and economy.

Governments are the primary party responsible for laws and regulations that aim to protect society. In Western Democracies, executive, legislative, and judicial bodies all contribute to the way that technology is regulated, based on historical, national, and even international norms, customs, and customary law. Regulations in democracies are often

formulated in the "public interest," although they are not immune from interference [58]. In other countries, regulations may be developed by a centralized authority, like the Communist Party in China (via the National People's Congress [102]) or the monarchy of Saudi Arabia, and enacted through a variety of agencies, public-private companies, and methods of indirect control to achieve national goals. Policies and regulations developed by highly centralized regimes may employ "Paternalist" approaches to benefit the good of individuals, like maintaining social stability, preserving the central authority, and competing on the international stage [68]. Laws and regulations are also defined, depending on the country, by both statutory and case law, making both the development and interpretation often very complex. National leaders may disagree with one another on how technology should be governed, including issues like internet protocols and freedom of expression online. These disagreements manifest themselves as disputes and impact the operations and security of people, companies, and the governments themselves [14, 68].

Governments are also home to some very cooperative approaches to managing data privacy and security. Standards development organizations (SDOs), as well as nongovernmental industry regulators, bring together government officials, and industry experts, in venues for cooperation that have been incredibly successful. Examples include organizations like the International Telecommunication Union (ITU) which is a global governance body that predates the UN; the International Organization for Standardization (ISO) which brings together national standards organizations; and the UN Internet Governance Forum (IGF) [14, 39].

Critical infrastructure is also governed by national, regional, and local governments. Studies of cyber warfare and espionage highlight critical infrastructure as a serious threat surface that needs to be protected. These cyber and physical systems, if compromised, would have a "debilitating impact on ... physical or economic security or public health or safety" [67]. While critical infrastructure may be heavily reliant on enterprises, discussed

below, the responsibility for success and failure still lies with government agencies.

2.3.2 Software Producers

Software producers, including commercial, government, and nongovernmental organizations that create and use software, possess substantial power that can have drastic impacts on countries and individuals. It should be noted that some private companies can rival governments in their power, both economically and in force. Prominent monolithic software producers like Meta, Apple, Netflix, Alphabet, and Amazon, have the economic and human resources to challenge and influence governments for their own benefit. Companies in other industries, particularly extraction, like mining and petroleum, also utilize physical security resources to fight against violent combatants.

Enterprises are responsible for much of software production, delivering products for consumers, businesses, and government agencies. Enterprise software offers a wide threat surface for potential cyber attacks. Cyber crime often targets vulnerabilities in commercial software. Cyber warfighting also exploits these vulnerabilities to achieve military objectives.

Software-producing companies are not limited to just large software corporations, they also include non-governmental organizations (NGOs) like charities, universities, community groups, and hospitals, as well as international organizations like the Red Cross and UNHCR. They can also include government agencies that implement and deploy software for individual constituents and other government agencies. These organizations often handle very sensitive information and make use of commercially available software as well as tailor-made solutions.

Companies that create software must deal with normal organizational conflict, such as the issues defined by Jehn: task, process, and relationship [44]. Workers, namely software

engineers, may dispute with each other regarding tasks that must be completed, processes that enable their tasks (or other organizational behavior), and relationships with other colleagues. These conflicts can be healthy, but can also lead to unfavorable performance and unintended consequences.

Software producers must also comply with laws and regulations established by governments with jurisdiction over them. Those requirements can vary between national and local governments, by industry, by enforcement mechanisms, and are subject to change. This, along with other factors, make regulations difficult for a company to interpret [70].

2.3.3 Users

Users are the everyday people that interact with software. This could mean a non-paying customer, a business client, or an administrator. You and me. While our experience with software may be easy to share in conversation, the empirical study of our interactions is significantly more complex. Behavioral economics, cybersecurity pedagogy, human-centered computing, social psychology, and public health are all fields that endeavor to study how individuals interact with software security and data privacy. There are mixed results.

Users of software broadly understand the need to be concerned with data security and privacy [8]. However, the level of concern may vary, from wholly unconcerned to abject disquietude. Data collected about users that incorporate the most risk include education, health, and financial information. In the US, these data are regulated. In Europe, even more data collection and data processing practices are regulated [28]. Privacy is even enshrined as a human right [14]. Nevertheless, concerns and interests for privacy can vary between cultures, and may require different approaches depending on a user's cultural background [9]. In addition to cultural differences in perception of privacy, users' abilities to protect

their privacy and data vary by jurisdiction [14]. Moreover, data collected and processed by companies are subject to complex policies that users struggle to understand [4, 8, 14]. These complexities make it difficult for everyday people to protect their privacy and personal data.

From a power perspective, individual users are the weakest compared to enterprises and governments. Nevertheless, we still have influence. Users can contribute to software development by sending feedback to software producers. Individuals can similarly submit feedback to regulatory policy development through their elected officials and systems like Regulations.gov in the US, and Data Protection Authorities in Europe. In some cases, individual citizens can file suits against enterprises and organizations, although there are frequent legal obstacles. Organized groups of users also have impact on the development and governance of software. Advocacy organizations like the Access Now, Electronic Frontier Foundation (EFF), Future of Privacy Forum (FPF), and International Association of Privacy Professionals (IAPP), all represent the interests of users in a variety of issues related to software production.

2.4 Existing Models, Methods, & Frameworks for Analysis

My focus will be on categorizing actors, their conflicts, their cooperation, and outcomes for applied use by practitioners and academics with concerns in software security. In order to approach this, it is helpful to review existing models and structures that can help frame these concepts. Software security and software engineering ground my research, and in fields orthogonal to these, there are some methodological tools that may be useful. I have used, and will continue to use, grounded theory (GT) methods, which have been applied repeatedly in this field [40, 85] to bring together multiple fields of inquiry. For example, Straussian GT supplies the "conditional/consequential matrix" to explain both the context

surrounding the topic of study, and the conditions that give rise to the phenomenon being studied [46, 86]. The models, methods, and frameworks below come from multiple domains in order to create new tools for studying the real world. They help frame and construct the context for interdisciplinary study of conflict and cooperation in software security.

2.4.1 Conflict Analysis

Multidisciplinary conflict analysis tools can help provide insight into actors, behaviors, beliefs, underlying issues, interests, goals, etc that foment conflict. These models and frameworks have been applied in various situations, from interpersonal to international issues, and can be adapted for managing social conflict in software security. Practical models for analysis include timelines, stages of conflict, conflict mapping, and force-field analysis. These tools can help inform strategies to address conflict, influence policy, intervene directly, and address consequences, as well as evaluate the outcomes of the efforts [30].

Early work, like Coser's *The Functions of Social Conflict* helps ground the study of conflict in theoretical social science methods through a multi-part model that describes, at-scale, the characteristics and impacts of social conflict. This model includes broad categories of conflict and group boundaries, hostility and tensions in conflict relationships, conflict with in-groups, and conflict with out-groups [20]. Later work continues to develop, implement, and evaluate tools for conflict analysis and peacebuilding that can be applied at interpersonal, intergroup, and international levels of society [30]. Applied and scholarly work is conducted in nearly every industry and area of society, including all types of dispute resolution methods.

Pruitt and Kim synthesize studies of structural and systemic conflicts and show that they can arise from three levels, the issues themselves, the relationship between parties,

and broader social and structural systems. They also show that these social conflicts can have positive and negative outcomes. Positive outcomes include changes to unjust policies, discouragement of poorly formulated premature decisions, and the reconciliation of legitimate interests between parties. As discussed elsewhere in [20] and [44], conflict can also help with group solidarity and cohesion, when groups overcome issues within the group, and when they organize against competing groups. Negative outcomes of conflict can include physical and psychological harm, long-lasting trauma, and harmful effects on society [74].

Conflict analysis methodologies can be applied at the interpersonal, intergroup, organizational or intra-group, and international levels. They provide theoretical and practical tools to understand a variety of conflicts and bear application in the study of software security in order to improve outcomes for stakeholders.

2.4.2 Software Engineering Research

There are multiple approaches in the software engineering domain that could be applied to model conflict and cooperation in software security. For example, approaches to engineering security in the software development life cycle (SDLC) have grown as the need for software has grown. A systematic mapping study of 118 studies revealed six categories of 54 approaches to incorporating security across the SDLC [63]. In empirical research, ranking from most formal to least formal, models often take the form of ontologies, taxonomies, categorizations, and frameworks. These representations can be used to model the real world for computation and for requirements engineering. For example, a systematic literature review of models of legal requirements includes approaches like logic, knowledge representation, access control, and goal modeling [70]. These models can help software engineers identify conflicts between software capabilities and legal restrictions.

Software and its use is getting increasingly complex, as different applications often need to be interoperable with each other, including in personal and business settings. One concept for describing this interoperability, and its impact on quality and security, is the "value chain" which can help identify the risks of integrating multiple pieces of software together in creating a final product [12, 87]. Another concept is the "software ecosystem" which describes the interconnections of disparate software and how new software can be added by a single software producer or a third party, revealing security threats, among other things [37, 54, 87]. Studies of software ecosystems can help reveal issues that can lead to insecurity. Still a third concept for studying threats that arise from interoperability is the "software bill of materials" which is a "machine-readable inventory of software components and dependencies" and is used in software development in industries like healthcare, automotive, and energy [89].

To incorporate users in models, we need to look both at how they are viewed, and how they view software and cyberspace. Users can be viewed as consumers or citizens, groups or individuals, and sometimes as stakeholders [88]. Users might view software as "major technology companies" that can be regulated [94], necessary services, or disruptors that can improve their lives. Users' ability to consciously contribute to software engineering is limited [88]. Usable Security & Privacy (USP) and Privacy-by-Design (PBD) are some of the more prominent ways that users are incorporated as stakeholders in software security decision-making. USP presumes that security cannot be effective if all users cannot use software securely, whether they are administrators or non-technical [33]. PBD, introduced by Canadian data privacy official Ann Cavoukian, posits that "privacy cannot be assured solely by compliance with regulatory frameworks; rather, privacy assurance must ideally become an organization's default mode of operation" [15]. Complementary frameworks for modeling privacy threats include LINDDUN [25] and Privacy Impact Assessments [66]. All of these frameworks provide systematic tools for software producers to cooperate on

data privacy and security needs when developing software.

Software engineering research in which regulators, software producers, and users appear together is not common, so it is important to bring together concepts from a variety of research areas within the field. These studies help introduce some of the concepts that will be helpful in empirically studying the conflicts that occur between the disparate stakeholders responsible for, and that benefit from, software security.

2.4.3 Management & Policy

Managerial frameworks and models of conflict within software firms abound. From Agile to eXtreme programming, waterfall to Continuous Delivery, approaches to developing software are popular even outside of the field, including design thinking and "lower case 'a' agile." Within these business models are inter- and intra-organizational, as well as interpersonal, approaches to conflict management to help software teams overcome obstacles and meet goals [44, 49, 99]. Research combining these software development methodologies with software security needs is more limited. The field of requirements engineering offers models for managing conflict as it covers the end-to-end needs of eliciting requirements, operationalizing tasks, assigning responsibility, and verifying the results [92]. One model for fulfilling the requirements of set goals focuses on negotiation [75]. The elicitation, traceability, and verification of security requirements may necessitate complex technical-legal expertise, and tools exist to support the cooperation between engineers and legal teams.

For technical-legal practitioners, various structures can be used to create and interpret the law and have varying degrees of influence in the development of software. Solove's taxonomy offers an exhaustive structure that includes all the legal considerations for implementing privacy in software [84]. The Fair Information Processing Standards (FIPS) are

a major set of guidelines that have driven legislation and regulations. Originating with the OECD in the 1970s, "FIPs are a set of internationally recognized practices for addressing the privacy of information about individuals" [34]. Recent consanguineal regulations, like the GDPR, attempt to impose the practices set forth in FIPS on software producers. The development of FIPS led to later organizational assessment frameworks like ISO 27002 and NIST Special Publication 800 series. These frameworks can help enterprises measure their information security practices and make improvements. They can also be required practices for software that handles protected data for governments, healthcare, financial institutions, and more.

A model of "maturity" can help determine where a cyber program is succeeding and where it has room for improvement. The Cybersecurity Capacity Maturity Model for Nations (CMM) developed at the Oxford Martin School provides a "methodical framework designed to review a country's cybersecurity capacity" [1]. This nation-level approach covers many of the dimensions crucial to providing data privacy and security. It can be applied to national programs for evaluation and planning to evaluate and improve cybersecurity strategy and inform operations. By homing in on "maturity" across dozens of factors, government officials can set strategy and goals in cybersecurity. Further research from the Global Security Cyber Capacity Centre, which created the CMM, also reviews other related models [21].

Internet governance is an international arena of public policy that has widespread impacts on technology and society. Brown and Marsden break down internet governance and regulation into three competing approaches and two justifications to achieve economic, societal, and human rights benefits. They identify market-led self-regulation, state-led regulation, and multi-stakeholder coregulation as divergent approaches. These approaches are justified in two different ways, "those based on human rights ... and those based on economic efficiency" [14]. O'hara and Hall identify the public and private actors that actually

compete for how to govern the internet, particularly in the United States, European Union, Russia, and China [68].

Studies of the multistakeholder approaches to policy development incorporate the contributions of international organizations as well as nations to technical regulations [14, 35, 39, 68, 98]. Richard Hill, a practitioner and researcher, maps the governance bodies of the internet through a practical multi-stakeholder model. Agencies like the ITU, W3C, ICANN, and others often have overlapping or conflicting purposes that can be difficult to understand, and they issue requirements and recommendations that can be very complex [39]. Software producers, increasingly operating in the cloud, must incorporate global regulations, protocols, and practices into their work. Practitioners often also contribute to the development of those recommendations and standards, both as independent contributors and through their employers [77]. One global effort is the UN Secretary-General's Roadmap on Digital Cooperation, which is a set of recommendations for the international community regarding things like digital trust and security and improving "digital cooperation" [35].

Applied studies like those above, which describe or model the real world of public policy, can help software engineers understand the arcane international and national landscape of governance, and where their efforts are best used when trying to meet requirements from disparate stakeholders.

2.4.4 Regulatory Compliance

There is practicable research on software security compliance to structure both theoretical and applied analysis of cyber conflicts. Analysis of existing laws and policy recommendations provide important tools for analyzing breaches, including their precursors, impacts, and aftermaths with regard to all stakeholders.

Lauber and Böhme outline the characteristics of disclosure laws, specifically the types of reports, whom they are meant to address, the objectives of the laws, and their cost effects [52]. The characteristics include distinctions between the types of breaches that need to be disclosed: security and privacy. Additionally, the subjects of the disclosure distinguish between authorities and affected individuals. They also draw on a principal-agent theory of compliance, where the government acts as a principal to incentivize the software company as an agent.

Approaches to notification about data breaches are included in [79], which describes three existing models of informing about data security leaks and proposes a fourth model. These models take into account not only the laws that are in place, but also the role of the consumer in coordinating responses to data breaches. The three existing models describe the different types of notice that the breached company needs to address, based on the law. In each model, the software producer may be required to disclose the type of breach that occurred to affected users, and may need to share with third parties as well.

2.4.5 International Relations

The field of international relations (IR) has established methods and empirical studies that contribute to software security research. Foundational IR research methodologies like Foucault's "*dispositif*" and "genealogy" provide a valuable balance of formal and informal concepts to create practicable methodologies for empirical research [98]. Genealogy, introduced by Nietzsche and extended by Foucault, provides theoretical grounding for case study research [95], similar to the use of taxonomies and categorizations. Whiting constructs an IR interpretation of cybersecurity using the concept of *dispositif*, specifically investigating the impact of knowledge and power by governments and corporations on various types of cyber conflicts [98].

One applied IR model of cyberspace is Joseph Nye's "regime complex." Nye defines a regime as a set of norms and institutions, for example, internet technical standards, global intellectual property governance, and the alliances within the intelligence community. The regime complex expands on these arrangements, in cyberspace specifically, via their relationship with one another, and the model stresses the "importance of linkages of cyber to normative and regime structures" [65]. This is valuable to IR and cyber strategy, but has limited expressions in software engineering.

In the IR book *The Fifth Domain*, Richard Clark and Rob Knake discuss the roles of different levels of actors in securing cyberspace, although they do not put forth a formal model. They argue that it cannot be solely the role of the government to govern and protect cyberspace as it does land, sea, and air. Instead, different levels of actors must be included, including industry and individuals. However, this requires a degree of collaboration that has not been reached. They call for renewed thinking about "how the government should be interacting with the private sector to further erode the offense's remaining advantages" [18, p. 112]. Lucas Kello contributes a framework of cyber conflict in the international arena, defining disruptive forces that lead to technological revolution at a grand scale, including a re-ordering of the international order. The severity of these forces ranges from the introduction of new technology that changes national decisions, up to a "systems change" which can "challenge the traditional supremacy of states" [45].

In conflict analysis and international development, practical models are used to plan and evaluate aid, development, and capacity-building projects. The Logical Framework, or logframe, is the standard matrix used by the US Agency for International Development (USAID) for their programs [3]. This practical tool helps government agencies and non-governmental organizations structure their goals and actions in order to ensure the best outcomes for the beneficiaries of their programs, and measure success. Tools like this can help provide real-world examples of how conflict management plans are created and imple-

mented by both public and private actors. Similar tools are employed when using software in conflict and disaster zones [43].

Studies of and practical tools in international relations are important to studying cyber conflict due to the international nature of the field. Security threats and actors are not limited by geographical boundaries, and it is important to connect stakeholders across the globe in order to get a complete picture of opportunities for conflict and collaboration.

2.4.6 Theoretical Frameworks

A handful of theoretical frameworks can help with analysis across these different disciplines, incorporating the potential actors in a cyber conflict, and the interactions between them. A review of theoretical and empirical findings regarding data privacy issues covers a wide swathe of options [56] that are backed up by other studies. These concepts, including theories of justice, social contracts, and social exchange may be necessary to explain the dynamics of implementing software security. Frameworks from other fields like environmental policy, public health, and intersectionality can also support deeper investigation of the disparate aspects of software security conflicts.

Justice Theory offers two dimensions to investigate how parties perceive conflict and cooperation proceedings, procedural and distributive. Procedural justice means that the parties are satisfied with the dispute resolution process, regardless of the outcome. While they may not have received what they wanted, they perceive the process as fair. Distributive justice means that the parties are satisfied with the outcome, regardless of the process. When parties attempt to overcome a conflict, these theories of justice can help evaluate whether the parties will be able to move forward with cooperation [7, 56].

One framework posits that parties will evaluate their approach to managing the conflict based on various priorities, including their interests, rights, and power. Conflict manage-

ment based on interests is likely to bring parties together to solve problems mutually, and requires the least amount of resources. Rights-based approaches incorporate contracts, laws, and courts. Using power to resolve conflict involves coercion and pressure so that one party gets what they want. Rights- and power-based efforts require more resources to resolve and result in less satisfactory outcomes for the other parties [91]. The specifics of how these approaches are used vary by case, and negotiations often "cycle through" these strategies [53].

Social contract theory has been employed to study norms and expectations between organizations and consumers [56], as well as between corporations, citizens, and governments [10]. The concept has also been touted by Chris Inglis, the first National Cyber Director in the United States, a role that reports to the President. Inglis argues that a "new social contract for the digital age" will help support cooperation in cyberspace [42].

Social exchange theory explains the relationship of parties and their transactions, for example between marketers and consumers [56, 61]. In terms of data privacy, it explains what customers may be willing to give up in a transaction, for example money or their personal information. This has important implications for services that are offered for free to the customer, but where the company uses the customer's data to make a profit.

A theoretical framework that empirically contributes to the context of cybersecurity at the macro and micro level is the study of "cybersecurity capacity." Cybersecurity capacity refers to "individual's, organization's, or nation's resilience to security threats." In [26] Dutton et al study the importance of a country's wealth and size in relation to the scale and centrality of internet use, along with indicators of cybersecurity capacity to understand end user cybersecurity problems. This model incorporates quantitative measures of "managerial, technical, social, legal, policy, and regulatory initiatives" from multiple countries to determine the benefits of national cybersecurity capacity to protect end users from crime, terrorism, and warfare in the cyber domain [26].

Borrowing from environmental policy is the theoretical framework of "policy choice" which incorporates institutions, problems, and discourse as inputs for actors and their decisions, which results in a policy instrument to make a change [11]. This approach to understanding how regulations are created includes the concept of "distributional conflict" which explains why some groups may be opposed to particular policy changes based on their interests. Distributional conflict in software security might occur when e.g. software producers do not want to incur the costs of adding security to their products, users do not want to expend resources learning how to protect themselves, or regulators avoid contributing resources to enforcement.

The study of intersectionality provides a theoretical framework to help incorporate diverse populations that need to be included in public decision-making. In public health, using intersectionality, as well as critical race, feminist, and gender theories can benefit historically oppressed and marginalized populations [13]. Public health offers approaches to improving cybersecurity [82]. Additionally, the unique data privacy and security needs of marginalized groups have been distinguished from other populations [2, 36]. It is crucial to bring in the perspectives and needs of all populations, including "racial/ethnic minorities, LGBT people, low-income people, and those with disabilities" [13] to tackle cybersecurity problems.

Multiple theoretical frameworks may be necessary to describe different aspects of a case being studied [16, 86]. The theoretical frameworks described above informed my grounded theory research throughout the process, and there were others that I identified later as well. This short list covers some theories that were applicable in this multidisciplinary study.

Chapter 3: Methodology & Approach

This dissertation uses grounded theory and case study methods to investigate the characteristics of software security that are directly connected to social conflict and cooperation, in order to create theories that can be applied in the field and assist further research. I have taken the broad context of social conflict in software security and narrowed it down to data privacy and security disputes. According to Strauss and Corbin, "the distinction between micro and macro often made by researchers is an artificial one" [86, p. 162]. At scale, multiple disciplines like those described in Chapter 2, including software engineering, international relations, conflict management, and cybersecurity, can all contribute to software engineering practice and research, and they are necessary to answer the most complicated questions whether micro or macro. My research will address questions that need to be answered concurrently; engineers, users, regulators, and their organizations should be able to understand each other despite friction or anxiety.

This dissertation will develop a grounded theory on social conflicts that occur when software is put into practice in order to promote data privacy and security in cyberspace. It will contribute to software security by helping three critical stakeholder groups work together to mitigate unauthorized and inappropriate use of data through meaningful, practicable ideas.

3.1 Grounded Theory Approach

Grounded theory (GT) has been demonstrated as an effective research methodology in information systems and software engineering research [40, 57, 80]. GT is associated strongly with qualitative research and is frequently applied to case studies as the unit of analysis [16, 40, 57, 80, 86]. Its use in information systems research is considered to be "more advanced than in other fields" [57], and has yielded thorough and practicable guidance such as through Socio-Technical Grounded Theory (STGT) proposed by Rashina Hoda [40, 80].

Initially, I considered several different approaches to GT, such as Glaserian or constructivist, where rigidity is less necessary [46, 85]. However, given the interaction of heterogeneous disciplines necessary to conduct this research, it is helpful to have a more formalized guide to follow. Ultimately, the GT methodology, and the Straussian approach specifically, helps support my desired empirical and applied outcomes. Furthermore, many aspects of my approach, including using existing tools and structures, were also described by STGT [40].

While I did not specifically employ STGT, its description of grounded theory methods, including traditional approaches, provides a useful guide to evaluate both my methods and results. Based on Hoda's guidelines, my dissertation clearly demonstrates much of the "mature outcomes" described by STGT. Hoda's STGT also helps delineate a number of the factors most concerning to a novice doctoral research student, and disambiguates many of the concepts that are easily confused when using GT. For example, she details the "sweet spot" where GT is "most likely to succeed and indeed where it makes most sense to use," including human and social aspects focus; theory development; practice-based topics; complex and deep questions; primarily qualitative studies; and data collected through interviews and observations [40]. My methods, data, and results exemplify these character-

istics, supporting the validity of my research, and demonstrating why GT was an optimal approach.

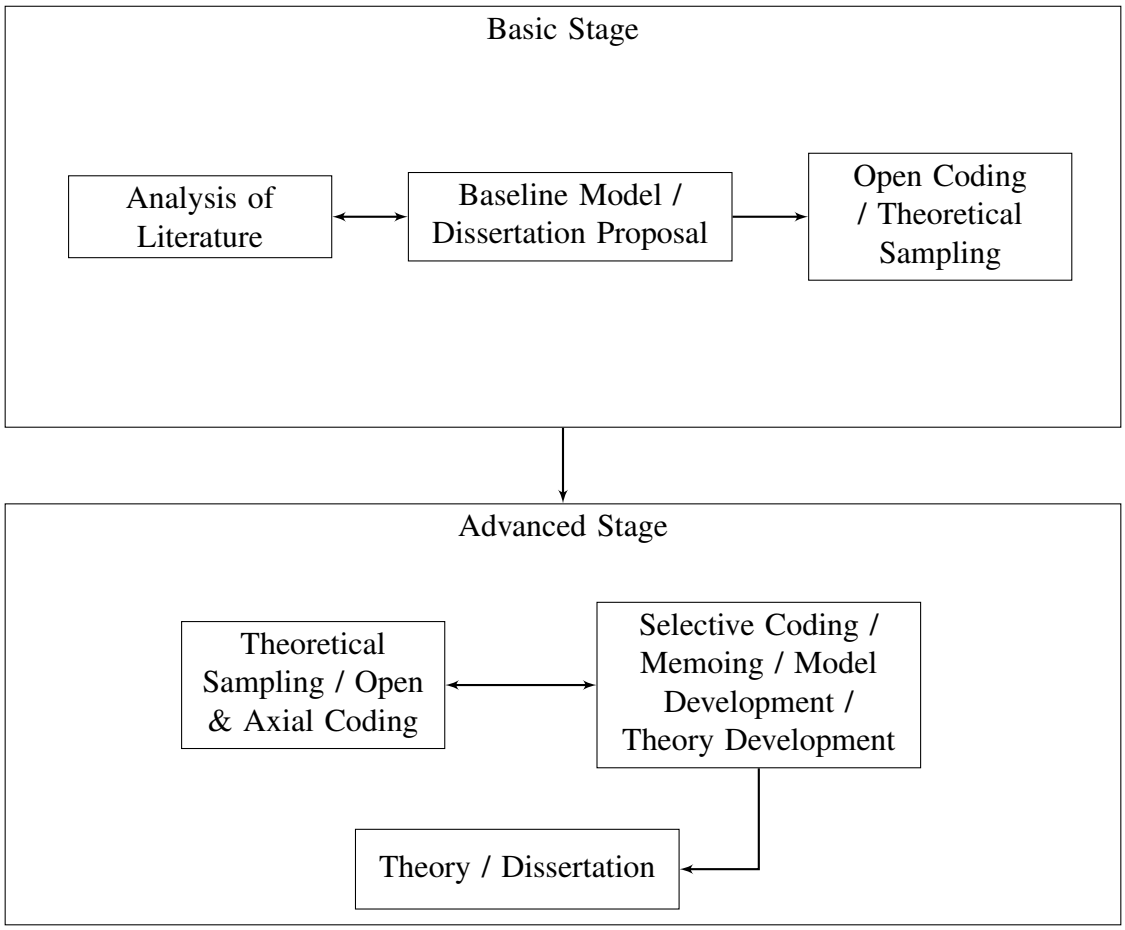

Figure 3.1: Method Steps Flowchart

The STGT method includes two key stages, with steps, procedures, and options for theory development, and progressively emerging outcomes of the theory [40]. In this section I will describe my methods as they align with this approach, as well as with GT more generally (also see Figure 3.1). The first stage is called the Basic Stage, and includes the standard GT steps of literature review, pilot data collection, and open coding. This stage resulted in the initial protocols for data selection, the baseline model, theoretical sampling and rounds of coding for the first few cases, and finally my dissertation proposal. During the open

coding phases of the first two or three cases, there were many new codes emerging. However, as each case was coded the coding scheme became more stable. The second stage is the Advanced Stage Theory Development, which included ongoing theoretical sampling, axial coding, selective or targeted coding, and reporting the theory. While I open coded each case, by the fourth case I was able to move quickly to axial and selective coding based on the maturing coding scheme, and rely on the model that was emerging from it. In the fifth and final case, I necessarily avoided changing the coding scheme, working directly from the existing model to analyze the case and confirm the effectiveness of the model and theory.

By relying on GT, it is straightforward, both ontologically and epistemologically, to identify modes of conflict and cooperation in software security at the micro and macro levels. The objective is not to create a litany of all possible conflicts and cooperation that can occur in this area. My goal is to create a theory that can be helpful for software engineering researchers, and could provide useful resources for software producers, and their user and regulatory counterparts as well.

3.1.1 Basic Stage

My initial steps included a literature review and background (Chapter 2), which demonstrated a gap in existing theory where I would conduct my research. My review of the literature covers sources and evidence that cut across the field of software security and can help support my novel research. Additionally, my analysis of these sources at this stage helped formulate the initial concepts to create my baseline model. The basic stage also includes the early rounds of theoretical sampling to select the first two-three cases, and the initial open coding of each new case.

Early on, I followed the initial phases of Straussian GT with some success, relying on

its procedural steps. I heavily relied on common approaches from the start of my research, including employing an abbreviated version of the so-called 6-C's to support coding: context, conditions, action-interaction (also called causes), and consequences [40, 86]. This methodology was particularly valuable when combining micro and macro issues, such as through the Conditional/Consequential Matrix [46, 86] for analyzing case studies.

Through the Straussian approach to developing the GT, I focused on "maximizing the similarities within and between concepts" [86, p. 141,155-6]. I started by connecting concepts through an introductory interdisciplinary investigation of the literature (see Chapter 2) that incorporates the most relevant fields of inquiry, including politics, software engineering, cybersecurity, organizational management, and conflict analysis. I also introduced my baseline model (see the next Section 3.1.2) based on the literature and background sources for studying the context of cases of social conflict that involve regulators, software producers, and users. This structured approach helped bound cases and ensure that they meet the research goals.

After defending my proposal, the next phase of the research was to select an initial set of cases and conduct open coding. The GT fundamentals provided a "collection approach" that helped structure the initial codes I used. For example, the pilot case I chose, Illuminate Education, incorporated the context and conditions I identified: a social conflict that concerns issues in data privacy & security, and includes software engineers, users, and regulators. In this case and the next, I analyzed the conflict and attempted to evaluate it using applicable theoretical frameworks. I evaluated the outcome based on how the stakeholders perceived it, and how it may have had an impact on the broader context. I was able to use descriptive and in vivo coding at this early stage to begin my analysis [16, 60].

My earliest steps in the basic stage, such as my interdisciplinary literature review and open coding, substantively supported my fieldwork later on. For example, the conditions for the conflict I described initially require a triad of actors (Figure 3.2), but those are simple

categories, and further coding was successful in identifying stakeholder-specific conditions in the first case analysis. Also, in the conflict management action-interaction following a breach, I observed a multitude of approaches, which I was later able to code for patterns. This resulted in an early iteration of the baseline model into a content-analytic summary table that included data from multiple cases [60]. In subsequent case analyses I occasionally returned to the earlier codes for fine tuning. Additionally, I used rigorous methods for data collection, discussed in Section 3.3, particularly when relying on secondary sources and extant literature to ensure it was credible [40, 57].

Based on this basic phase of analysis, I developed the initial model and codes for exploration, leading to the advanced stage later on.

3.1.2 Baseline Model

Based on the literature review and background, I created an initial model to frame and bound my pilot case analysis, and prepare for analysis of further real-world case studies. This model structured both the overarching context and narrowed issues for my inquiry. Based on my experience and research on asymmetric conflicts and software engineering, I was able to establish this model for early-stage case analysis to undergird the later phases of research to produce empirical results. Those results will contribute to the ability of stakeholders to navigate interactions between and among different levels of society. This model incorporates a broad understanding of social conflicts (the context), a narrower view of instances of disputes (the conditions), the approach to managing the conflict (action-interaction), the outcomes of the dispute (consequences), and the resulting impact those outcomes may have on the original context.

The initial model consisted of five nodes (Figure 3.2). The nodes were based on a GT coding family that includes the context, conditions, actions, and consequences of a system

being studied [86]. The first node introduces the main area of investigation for the research, representing the overarching context of possible cases that could be used in this study, and acts as a start/finish line. This context node represents the space of possible social conflict in the field of software security. The context comprises conflicts that exist between software producers, regulators, and users in trying to achieve data privacy and security goals. This abstract, global node is instantiated, through a conflict action such as a data breach, into the condition node. The condition node comprises the specific and necessary actors that are party to the conflict being analyzed and are engaged in a practical dispute: actual users, software-producing companies/organizations, and government regulatory bodies/agencies ,as well as an incident. The parties that provide the conditions for their conflict in the second node give way to the third node, an action-interaction event. The parties analyze the conflict, make a choice, and interact, leading to an outcome, or consequence. The stakeholders' action-interaction to manage the conflict connects to the consequence node. The consequence is the outcome of the approach to managing the conflict. Finally, the consequence of this conflict may lead to further impacts on the global context. The outcome of a particular dispute has a relationship with the broader social conflict in that it can have an impact on future, similar cases which can be evaluated.

The baseline model from the beginning seemed quite transferable. For example, as a model to describe cases, it is possible to swap out specific actors. More broadly, however, it may be possible to swap out different types of actors, particularly those in regulated environments. This means that instead of being limited to software producers, it could be possible to use telecommunications providers, the healthcare industry, or financial institutions. Instead of government regulators, it could be self-regulatory bodies. Instead of users, it could be constituents or customers. Subsequent versions of the model, following each phase of coding, will limit this broad applicability. Ultimately, the grounded theory will not be nearly as transferable outside the domain, and will be focused on software security

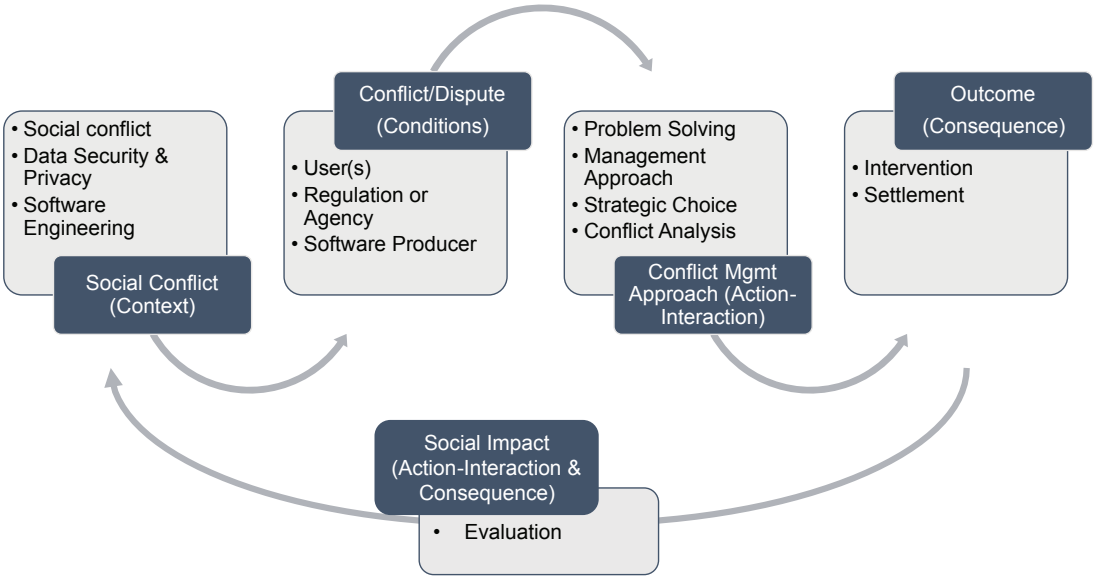

Figure 3.2: Baseline model created to conduct case studies

due to the cases being studied. However, if the cases are selected carefully, they can help ensure the theory is generalizable and externally valid to various cases in the field.

Node Details

The *context* represents the zone where the possible (or inevitable) conflict occurs between the triad of users, software producers, and regulators. For the purposes of this research, this space is limited to social conflict with regard to data security & privacy and software engineering. This context provides boundaries for possible case studies. It means that there must be a social conflict, as defined in Section 2.1.1, that arises from the field of data privacy and security, and implicates software engineers.

The *conditions* represent the realization of a prospective conflict between parties. By comparison, the conditions for cooperation would be that each stakeholder acts according

to their role and any rules set contractually, legally, normatively, etc. When one or more of the parties are under the impression that their goals are at odds with someone else's goals, there are the conditions for a conflict. My case studies will focus on when the conditions implicate all three parties and goals are not perceived to be aligned. Case studies must also result in an observable, real-world dispute. It is possible to use conflict analysis methods, such as conflict or stakeholder mapping, to analyze the conflict (see Section 2.4.1). Conflict analysis at this stage can help understand the underlying issues that led to the conflict, as well as impact the next phase, the approach to managing the conflict.

The *action-interaction* that bears studying is the approach to managing the conflict, and it connects the conditions for the conflict to the consequences. It may consist of both analysis and action by the parties, incorporating "strategic choice" [74] to determine the appropriate approach. See Sections 2.1, 2.4.1, and 2.4.6 for further information about approaches to managing conflict. Maybe the actors chose to file a complaint with the data protection authorities. Alternatively, they could have chosen to do nothing, or they may have had standing to sue the company directly, depending on the jurisdiction. They could also have attempted to settle out of court, such as by pursuing negotiations directly. What type of compensation they are seeking is also a matter to study.

The fourth node is the consequence, the outcome of the conflict management approach. Cooperation and collaboration are more likely to lead to a satisfactory outcome for all parties involved. Based on the interest-rights-power model, interest-based negotiations would yield better results for each party than resorting to rights- or power-based approaches [91]. It will be possible to evaluate the outcome for the stakeholders using theoretical frameworks like those discussed in Section 2.4.6. For example, Justice Theory would test whether the parties thought both the process and the outcome were fair [7, 19, 23].

The consequence (outcome) of a specific dispute may lead to yet another action-interaction, and another consequence: a social impact. This is shown on the fifth node, which connects

the consequence/outcome node back to the context in the first node. This refers to the fact that after a dispute is settled, it may change the global context for future disputes, such as through case law, new regulations, changes to behavior, etc. This is why we can consider the context node a "start/finish line," as a conflict has a starting context, and may eventually have an impact on that context.

The baseline model proved useful when approaching the pilot case, and quickly evolved to include new phases based on the empirical data and logical considerations when describing the processes and events that unfolded in each case. My goal was to choose cases that cover social conflict and have manifested an on-the-ground dispute. Going forward, using axial and selective coding methods, I expanded the baseline model, demonstrated the validity of the structure, generated categories and finally developed a theory.

The final model, described in Chapter 5, includes more substantive concepts that describe the behaviors and states of the stakeholders throughout multiple phases of the cases.

3.1.3 Advanced Stage Theory Development

The next step was the advanced stage of theory development and I continued to use Straussian approaches, which Hoda describes as a "structured mode of theory development" [40, 46, 86]. This emphasizes data collection and analysis in a structured way, including the use of existing tools and templates. Ultimately, five cases were chosen that demonstrated social conflict due to cybersecurity issues and software engineering in regulated environments.

This phase begins with axial coding on each case, after they had been open coded in basic stage analysis (See Figure 3.1 above). The results of my axial coding efforts include concepts both within and between the different actors and conflicts I investigated. My focus on "the complexity of the relationships between conditions, actions-interactions, and

consequences" [86] started to become a methodological differentiator compared to other research in the field, ultimately leading to novel knowledge. This includes generating new concepts about how the behaviors of stakeholders, both conflict and cooperation, are driven by regulatory policies, software engineering practices, and user privacy. The axial coding of each case, and between cases, helped refine the new concepts that I was identifying in each case. These codes substantially extended the baseline model, creating new phases beyond the initial five, and revealing systematic patterns of behaviors and relationships between the stakeholders.

Fundamental to the qualitative research was basic memo writing based on data collected from the mixed sources discussed in Section 3.3. My approach to coding at this stage included process and causation coding [60] to better categorize the behaviors and outcomes I observed. I also began exploring and explaining the case data using matrices to organize the parties, conflicts, approaches, and impacts over time. For example, the conditional/consequential matrix, effects matrices, and case dynamics matrices [60, 86]. Another effective approach, given the complexity of the cases, were causal network analyses, particularly within-case network analysis during the earlier stages of coding, and cross-case analysis later on. Compared to the initial case, the next cases were chosen to include different types of environments, actors, behaviors, and outcomes, which would improve the validity of the theory, and increase the applicability to more heterogeneous situations.

After axial coding, I moved to selective coding (also called targeted coding [40]) to fully develop the concepts necessary for a theory. Selective coding involved field memos and constant comparison to conduct cross-case analysis to develop the final model and theory. This included identifying patterns and subsuming lower-level codes while creating a coherent conclusion. Cross-case analysis at this stage started to include a thorough predictor-outcome-consequences matrix [60] that compared the event-states and behaviors of actors between cases. These methods helped support inductive and abductive reasoning

that began to indicate theoretical saturation, a crucial step for theory integration [16, 40, 86]. The result of this phase was refinement of my model into a coherent tool that could be used practically to analyze case data, particularly for my fifth and final case.

Following the first four cases, theoretical saturation started to become apparent. The categories I had developed were no longer changing or benefiting substantially from new data. In particular, the predictor-outcome-consequence matrix showed patterns between contributing factors in different cases, despite differences in antecedent variables and outcomes. At this point, I was able to begin theory integration and prepare for the final case to validate the theory. It was clear at this stage that my research would integrate evidence from empirical case studies that reflect conflict and cooperation in software engineering, data privacy, and security to support a grounded theory.

The final-stage effort was a lightweight validation through analysis of a fifth and final existing case. The first four cases chosen to construct the theory during the coding phases can be considered a "training set." Then I used a fifth case as a "test" to validate the theory. This helps in evaluating the effectiveness and validity of the theory and demonstrates its maturity. Relying on the causal modeling I conducted during the first four cases, I was able to confirm that the multivariate predictors I identified clearly showed the causal mechanisms behind the outcomes [60] based on a clear "chain of evidence" from my qualitative data [76].

Throughout the process, I adhered to the GT methodology to focus the research and ensure the dissertation can be used as an artifact in future research and applied in real-world situations. Through these stages I have created a grounded theory that can be considered "mature" based on Hoda's evaluation criteria: novel, useful, parsimonious, and modifiable [40].

Future work could use the model to predict the outcomes of other real-world cases. The ideal situation for this would be to identify a burgeoning case, apply the theory, and

predict the outcome. A practicable tool in grounded theory is the causal prediction model, which could be built based on the predictor-outcome-consequence matrix I developed, the Model-Case Matrix (Appendix **??**). This prediction model may be useful for predicting future outcomes [60].

3.2 Case Selection

Cases were identified and prioritized based on a variety of variables, including grounded theory methods like theoretical sampling, case study best practices, and maximizing the validity and reliability of the final theory. Case studies in general can increase knowledge about groups, organizations, and social phenomena. In software engineering research this includes "development, operation, and maintenance of software" [76].

Using the baseline model as an a priori construct [27], I chose cases that covered the triad of actors that could be stakeholders in social conflict. It was not enough for the conflict to affect only two of the actors, for example, simply a regulation's impact on industry, or a user's complaint directly to a software producer. Additionally, it was not enough to review "within-level" conflicts, such as corporate espionage through hacking, or an intra-agency dispute about new privacy regulations. Lastly, the conflict should have resulted in an observable, multistakeholder dispute where parties interacted with each other and expressed their disagreement, including outcomes from their approaches to managing that conflict. I sought out salient examples of data privacy and security incidents that provided a substantial amount of data for collection from primary and secondary sources, including interviews and archival data [76].

Taken together, the cases were chosen to support a diverse data set for cross-case analysis, which can help "[achieve] maximum variance along relevant dimensions" as an exploratory process for theory development [76, 81]. The total number of selected cases is

small, which means that they are not likely to be representative of all possible categories. However, there is wide diversity in the cases in their causes and their outcomes, which is valuable for supporting validity, discussed in Section 3.4.

3.3 Data Collection Protocol

After each case was selected, I performed multiple phases of qualitative research, including field research, as well as locating secondary (extant) data sources for desk research. Field research included interviews with subject matter experts. Secondary data collection included locating and evaluating existing quantitative and qualitative data. Ultimately, I selected five cases to analyze, each of which consisted of dozens of extant sources including journalistic, legislative, judicial, organizational materials, public statements, testimony, released internal materials, and more. I also attempted to conduct at least one interview with subject matter experts for each case, resulting in 3 interviews each pertaining to one case, and 2 interviews pertaining to a fourth case. One case did not yield any interviews, unfortunately. These sources of real-world data, as well as other academic repositories, can be incorporated as both primary and secondary data for case studies.

3.3.1 Field Research

Field research comprised interviews with stakeholder subject matter experts (SMEs) that were familiar with each case, including software engineers, legislative and regulatory practitioners, governance professionals, and user advocates. In order to interview these SMEs, I reached out to existing contacts, and made new connections with people connected directly or indirectly to the cases. These contacts come from industry work experience, past professors and instructors, as well as from networking outreach, such as at public conferences and meetings, and cold emails.

Once cases were selected, I identified stakeholders who were party to the conflict, or other SMEs who could speak to the specific cases based on their explicit experience. I conducted semi-structured interviews with subjects to ensure that I collected specific data about the case, as well as their experience, while leaving opportunities for open-ended discussions to get details that I may not have identified from other sources [76]. Based on my interview guide, the semi-structured interviews included background information about the interviewee, knowledge of and familiarity with the specific case being studied, and their experience with the software production, regulation, or use within the case. The interview guide included 26 questions, which included options based on the role of the participant, and were organized based on the timeline of the cases (See Appendix **??**). In order to be as flexible as possible for the interviewee, and to support recording, the interviews were conducted virtually, lasting approximately 60 minutes. Follow-up interviews were not necessary. While there was no need for sensitive information to be shared for the study, there are two areas of concern that need to be addressed. First, if an interviewee is party to a case, then their personal or private stories may be sensitive. Second is protected information, such as company secrets or classified information. In order to protect the interviewees and/or their employers, I received Institutional Review Board (IRB) approval to conduct the interviews, secured all data as required, and received consent forms from every participant.

In total, I interviewed five subject matter experts about four of the cases. I was unable to identify an expert to be interviewed about the Equifax case, and I found two to speak about the ICRC case. The Equifax case, which was widely known and widely studied, had such rigorous secondary data that it was straightforward to document the details of the case. In particular, a Congressional investigation report that included multiple rounds of testimony and the release of internal documents, thorough reporting by advocacy groups due to the high-profile nature of the case, and the numerous court documents from litigation. However, finding an expert to speak about the details of the case was difficult, and many

individuals who are experts in the field felt limited in how much they could say because of how long ago the incident occurred. The ICRC case involved two subjects because of some of the confusing internal approaches to software development. Details on the use of software by humanitarian organizations were limited, as were the unique features provided by the ICRC for its beneficiaries. Furthermore, the regulatory environment was very complex, given the international nature of the organization, and the specialized use of the software. However, SMEs familiar with the case were very interested in speaking about it in order to help promote humanitarian data privacy.

3.3.2 Secondary Data

Collection of secondary data, also known as extant texts, archival data, or third degree sources, was critical for analyzing the cases [16, 76, 96]. This data is comprised of software artifacts, legal documents, corporate and organizational reports, and journalistic sources from across society. For case study research, this data is crucial to complement data collected from interviews to support validity through "triangulation" [76]. I used methods described in Watkins [96] and Charmaz [16] to select and evaluate the secondary sources. Watkins' 2022 book, *Secondary Data in Mixed Methods Research*, details a variety of methods for evaluation and incorporation in multiple research approaches, including inductive investigation [96]. Charmaz is a grounded theory researcher and provides multiple practical approaches for including extant texts in GT research [16]. These selection and evaluation processes include multiple considerations and questions, for example: what was the purpose of the original research, who collected it originally, what is the context in which the data was created, who was the original intended audience, and whether my variables match those from the original study. By documenting and following these processes for evaluation, I was able to assess both the quality and appropriateness of each secondary

source. Evaluating quality helped make sure the data was reliable and credible, and appropriateness helped ensure that it was applicable to each case specifically, and my research more broadly. Once these sources were evaluated for quality and deemed appropriate for use, I incorporated them as I did primary data. Given the plethora of this secondary data, I referred to it constantly throughout the case studies.

As I conducted each case study, I relied heavily on secondary data. I evaluated each source as it was incorporated into the research, and regularly documented concerns or mitigating factors when they needed to be addressed. To evaluate the secondary data, I first considered the type of data it was, e.g. a software artifact, legal document, academic publication, journalism, company report, etc. These types would be assessed both for their benefits and their limitations. For example, a legal document may not provide technical details to accurately describe software implementation. A journalistic source may have a bias towards a particular policy approach. A company report may be skewed to show an issue in better light. A research publication may be limited in its applicability to my research questions.

In addition to the source of the data, I also evaluated the specific narrative, content, or underlying data to ensure that it was credible and applicable to each case. For example, legal documents were evaluated based on the politics of the legislature or court. Journalistic sources were evaluated for media bias and through their popularity and stated mission. Corporate reports were evaluated for their company or organization's interests. Scholarly research was evaluated for quality based, for example, on how many times it had been cited and its publication's impact factor.

To give a specific example, in the Illuminate Education case, I found articles in high school newspapers that included opinions and statements from students, teachers, and administrators who were affected by the breach. These were valuable to get actual reactions from a variety of affected users whom it would have been impractical to find and interview.

However, the articles were limited in their understanding of the pertinent regulations, and the technical aspects of the data breach. Additionally, I had to take into account some editorializing by the authors, but the quotes from fellow students and school staff (such as a school principal) were reliable. I was also able to find multiple high school news articles that expressed similar sentiments and behaviors, which, taken together, supported the validity of that set of data through triangulation.

Using secondary data sources helped provide independent sources compared to primary data, and even the weaknesses were used to frame my arguments [16]. For example, a secondary source that was seen to be particularly biased was used to show the perspective of the stakeholder it represents, such as a company or regulator. I incorporated these outside sources to scrutinize, not corroborate, my evidence. Secondary data of questionable quality or appropriateness were occasionally included, with the concerns highlighted. I also used the assessment process to help me choose cases that had more high-quality secondary data available. For example, when looking into a possible case, if there were few reliable external sources about the issue, I chose not to proceed. In the infrequent situation where two sources had discrepancies in the facts of a case, I resolved the discrepancy by relying on the higher quality source, or by disregarding the data if it was not important for analysis. Ultimately, I extensively used reliable secondary qualitative data by incorporating into the design and planning of the research, as well as for case analysis and inductive reasoning.

3.4 Threats to Validity

In order to maximize the quality of the research, I will use the four tests of construct validity, internal validity, external validity, and reliability [76, 101]. Below I explain how my methods satisfy the requirements of these tests starting at the design phase, and throughout the research process.

3.4.1 Construct Validity

Construct validity refers to how my methods address the questions I intend to answer. In order to support construct validity, my research was comprised of qualitative case studies that incorporated multiple sources of evidence. Qualitative sources include primary interviews from SMEs knowledgeable about the cases. Secondary data was collected from reputable journalists, recognized industry organizations, official legal documents including government-led investigations, corporate reports from companies involved in the cases, and more. The variety and quantity of these sources provides ample triangulation for valid data on the causes and impacts of the conflicts in the cases [76].

One threat to construct validity is the interdisciplinary foundation of the research. For example, different fields may use different terms to explain the same phenomena. This issue arose early on, for example, simply in defining the term "conflict," so it was necessary to be careful to clarify the terms used both during analysis and in the final results for the reader. Additionally, there were differences in constructing and articulating ideas from these different fields. This also occurred early on in the research when describing models from different domains like political science and software engineering. In these cases, where possible, I defined terminology that is consistent with the software engineering literature to try to keep concepts coherent.

Another related threat to construct validity was my lack of familiarity with some of the complex concepts in the cases, particularly legal approaches, and occasionally software engineering. I am not a lawyer or jurist, and I am not qualified to assess the legal theory behind legislative and judicial actions or outcomes. In the engineering approaches to cybersecurity, I am not experienced enough to say whether some methods of prevention or remediation were appropriate. This threatens construct validity because it means that it is possible that I misunderstood or misinterpreted key causes and outcomes in cases. I

mitigated this threat in two ways. First, I relied on expert explanations of these details, from both primary and secondary data. The public nature of these cases meant that I was typically able to find nontechnical explanations of what happened and use them as data, or have an SME participant explain it to me, and incorporate the explanations in the theory when applicable. Second, I was often able to abstract the very technical behaviors of both lawyers and engineers. In a sense, it did not always matter what narrow action these stakeholders took. It was important to document some of these actions, but it was the broader approach, as well as the logic behind it (the 'why'), that was more important for theory development. The result is that an expert reviewing any individual case analysis that uses my theory would be able to dive deeper into the technical approaches for their own purposes if they choose, and the overarching theory remains valid.

I also addressed construct validity by ensuring that each case was bounded by similar inputs and outputs. I chose cases that included a cybersecurity breach, that resulted in unauthorized access to data about individuals who had some regulatory protection, and resulted in actions taken by stakeholders to the breach to remediate or recover from it. The stakeholders necessarily included a company that implemented and/or deployed software, users whose data was accessed without appropriate permission, and regulators that had influence over the situation. All of these things had to have a sufficient amount of publicly available information for analysis. The result is that the cases focus on examples of social conflict, as opposed to e.g. cyber warfare, or cyber crime, where these criteria may not be applicable, and would have resulted in different theoretical outcomes.

3.4.2 Internal Validity

Internal validity concerns the extent to which I am able to represent my results as causal relations. To improve internal validity, when selecting each case I considered the data

breach, its precursors, the dispute that manifested, the approaches to resolving the dispute, the outcomes for the parties, and the consequences of the broader conflict. This logic model, showing a chain of cause-effect relationships, was established early in my baseline model, and was valuable in assessing the internal validity of each case study. During the analysis phases, I attempted to improve validity by matching patterns within and between cases, including deeper analysis of explanation building and logic models. Matching patterns within the cases in order to understand cause-effect relationships was important to the case studies and helped assure their validity.

I also attempted to improve internal validity by countering my assumptions with rival theories [101]. This included constant comparison between the emerging findings and additional literature [27, 40, 86]. I also attempted to select cases that appeared to contradict the results of previous case studies in order to exercise the evolving theory. For example, I included cases in the US and Europe, as well as issues arising from different regulatory regimes within those jurisdictions, and different types of companies that were breached. The emerging data from the cases helped expand the theory until I reached theoretical saturation, at which point I moved to the final case to test the theory. The result was that the broader research, including the additional literature and the new cases, continued to support my findings, indicating strong internal validity.

Another threat to internal validity was my use of secondary data and the potential biases from those sources that could muddy the final theory. To control for this, I assessed my data sources for potential biases, as discussed in Section 3.3.2, and made sure that my codes were not evaluative, nor assigned judgment to the behaviors and outcomes I observed [60]. In my case analyses, for example, I made sure to include descriptions of secondary data sources that clarified their potential biases. My close adherence to this objective approach yielded practical holistic and causation codes early on, and pattern codes later [60].

3.4.3 External Validity

External validity concerns the possibility of generalizing my findings, and how valuable they are to other people outside the research. There are two major efforts to maximize the external validity of the research. First is the use of multiple cases. The use of qualitative case studies is not based on statistically representative samples, instead, I carefully selected cases that border on revelatory on their own, with characteristics that are common to a wide variety of possible issues. The cases that I chose are representative of the common cybersecurity mantra about data breaches: it is not a matter of *if* a software will be breached, it is a matter of *when*. As such, I selected cases where the overall context was typical, including the data breach itself, the affected companies, the regulatory environment, and the user base, as well as the antecedent and outcome behaviors. These cases are typical such that other, similar stakeholders in the world could look any case and say "this could happen to me." At the same time, I analyzed the unique characteristics of the cases to develop the theory, but organized them to be "sufficiently abstract to cover the range of empirical situations" [16]. The result is a theory with rich and deep categories that can be useful for analyzing a wide variety of similar cases in the future, including their causes and outcomes.

The second effort to maximize external validity is the use of grounded theory. The grounded theory that I developed as a result of the case studies is widely generalizable because of my adherence to the best practices of the methodology [101]. For example, through constant comparison and integrating existing literature into the emerging theory, I also ensured that my data tied to existing phenomena, even if they were not already associated with each other [27]. The theory is also modifiable, that is, it can expand based on new evidence when it is applied in the future [40].

Limited cases are being studied, so future research could continue to develop the theory by adding additional cases, or relying on other research approaches. My final-stage,

lightweight validation test case (described above in Section 3.3) also helped characterize the level of saturation achieved, which will be useful to future researchers.

3.4.4 Reliability

Reliability is related to the ability to reproduce my research, and how it depends on my individual approach to get the results. I maintain a satisfactory level of reliability by adhering to the research best practices of qualitative research in empirical software engineering while studying cases that have a large amount of publicly available data. Reliability can be demonstrated through the concepts of rigor and credibility [40, 86]. With respect to rigor, I maintained detailed repositories and citations for the secondary data that I collected, and the interviews I conducted were with subject matter experts that can be easily reproduced with similarly experienced individuals. In terms of credibility, I have demonstrated evidence of clear understanding and application of the GT methodology throughout this dissertation. The entire process has been thoroughly documented and full details are available, which means that another researcher should be able to follow similar steps using the data that I have collected and come to the same conclusions.

Chapter 4: Case Data and Analysis

Based on the methods described in Chapter 3, I began with an initial pilot case study (Illuminate Education), followed by analysis of three cases where I developed a grounded theory and model of conflict and cooperation in cybersecurity, regulatory compliance, and software engineering. Finally, I selected a fifth case study (OPM) as a lightweight test case to evaluate whether the model and theory held up without revision. Below I provide a synopsis for each of the case studies I conducted, including key details and concepts that supported theory development. The synposes below were created in part using NotebookLM, a Google AI tool that used only my full case analyses as data sources, along with my editing, review, and additions. The full case analyses, including their respective citations, are in the Appendices.

4.1 Illuminate Education

Illuminate Education is a software provider for education institutions and districts, including primary and secondary schools around the US, counting millions of students as their users, in addition to teachers, administrators, and parents. Among their clients were the two largest public school districts in the country, Los Angeles and New York City, as well as districts in Colorado, Connecticut, Oklahoma, and more. These districts and schools, as well as their superior state and federal jurisdictions, employ privacy and data security privacy policies that regulate Illuminate Education as a software producer in this

field. These policies focus on protected classes of people, including students and minors. Illuminate Education's popular software services, such as PupilPath, were used for things like tracking grades and attendance, and included PII about the students and teachers. In January 2022, Illuminate Education suffered an outage to their services, which was later revealed to be related to a data breach. According to the New York Times, there was unauthorized access between December 28, 2021 and January 8, 2022. Ultimately, it was revealed that the records for at least 3 million students, across 605 districts, were accessed and possibly exfiltrated. After the breach, multiple lawsuits were filed by the parents of affected students against Illuminate Education in multiple jurisdictions, including federal court. These lawsuits included allegations of identity theft, future identity theft, and harms associated with loss of privacy. However, the cases were ultimately dismissed after reaching federal court. Contracts were also canceled with the company, and they suffered negative attention and criticism in the media and in the education technology industry. In 2025, a coalition of state regulators pursued action against the company, resulting in fines and ongoing oversight into their cybersecurity practices. Edtech remains a lucrative space for businesses, and a target for cyberattacks, with all stakeholders working to protect their interests.

Selection Criteria: This case was chosen because the primary users were students/ minors (a protected class), along with parents, teachers, and school administrators. Education technology operates in a regulated environment at the local, state, and federal levels, as well as by third-party industry regulators, due to their use of the protected PII of students and minors. However, at the time I chose this case, there had been limited action in enforcing these regulations, only a dismissed lawsuit against the company, and this ostensible failure seemed worthy of investigation. Years later, in 2025, after I had finished analyzing the case, new regulatory action introduced new data, and forced me to re-analyze the case. This yielded crucial results and made this an even more important case.

Context: Regulations relevant to the education technology sector focus on protecting students as a vulnerable and protected class. Federally, the foundational law is the Family Educational Rights and Privacy Act (FERPA) of 1974, although statutory and case law have limited its enforcement, often finding that individuals lack the right to sue in court for violations (a private right of action). Due to the perceived inadequacy of federal laws like FERPA and the Children's Online Privacy Protection Act (COPPA), some state and local jurisdictions developed their own regulations, including California, Connecticut, and New York, and even the New York City Department of Education (NYC DOE). Additionally, the industry developed a self-regulatory framework, the Student Privacy Pledge, which, although voluntary, is designed to be legally enforceable by regulators like the FTC and State Attorneys General.

Antecedent Behavior: Students and school staff used the software (like PupilPath) for daily tasks such as grading and scheduling. Illuminate Education was in a period of growth at this time, merging with other companies and getting private equity investment. High-level users, specifically school districts (e.g., NYC DOE), procured the software and enforced stringent contractual requirements, such as mandating the encryption of student data at rest. Despite these requirements, the records of at least 3 million students were compromised, and the company was alleged to not follow the best practice of having their data encrypted while at rest.

Response, Remediation, and Recovery: Parents of affected students actively pursued compensation by filing multiple class action lawsuits in federal court, alleging harms such as identity theft and loss of privacy. However, these lawsuits were dismissed. Some users had the services cut off entirely when contracts were canceled with Illuminate Education, such as in New York City, where the the NYC DOE (a customer of Illuminate Education) terminated their agreements. This forced schools in that district to undertake correcting behaviors, such as finding and deploying new software solutions (including using ad hoc tools

like Google or Microsoft services). State and federal agencies also pursued enforcement actions against Illuminate, culminating in a settlement agreement and mandated security practices. The company also deliberately restricted information about the incident, making only a few public statements, and actively getting court documents sealed.

Outcome: Despite the users' efforts and the consolidation of their lawsuits, the federal court dismissed the class action complaints, adhering to the precedent that limits individuals' ability to sue for compensation under federal education law. Simultaneously, client users like the NYC DOE adhered to the terms of their contracts and severed the relationship with Illuminate Education, while other clients continued working with the company. Nearly four years later, in December 2025, the FTC filed a complaint against Illuminate Education forcing the company to comply with new data security practices. Additionally, Attorneys General for three states settled with Illuminate for $5.1 million, including civil penalties, although that is not slated to go to affected users.

4.2 International Committee of the Red Cross

The International Committee of the Red Cross (ICRC) is not a typical software producer, but it does create software solutions for a variety of users to achieve its mission. Its users are comprised of a heterogeneous mix of international organizations, field staff, and end-users, all of whom depend on the software for critical and even life-saving operations. The end-users, called beneficiaries, are of particular importance, and they are the people that benefit from the services provided by the ICRC in highly sensitive situations like violent conflict and environmental disaster. With their iconic Red Cross emblem, the ICRC provides a variety of services to their beneficiaries, including reconnecting families who have been separated, which they have done for over 150 years. Today, this means implementing and deploying software through their Restoring Family Links (RFL) pro-

gram, which is deployed by field staff worldwide. The regulatory regimes that apply to the ICRC and its users are manifold, including disparate national requirements in the countries where they work, and international agreements like the Geneva Convention, as well as strict internal regulations.

In 2021, a breach compromised information of about 515,000 beneficiaries of the RFL program. These end users are a particularly vulnerable population, and malicious use of their data could lead to direct harm. Additionally, their privacy, diverse situations, and diffuse locations disrupt their ability to recover from the breach, such as through legal action. The regulatory bodies that are tasked with controlling and remediating the breach are also spread out among multiple jurisdictions, making it hard for anyone to act. The ICRC, as the software producer, had to act in the best interests of their mission, which takes into account their future operations and the well-being of their users, particularly, the beneficiaries. The users in the ICRC case fall into two categories: the beneficiaries (end users) and the National Societies (deployment users). The focus here is primarily on the beneficiaries.

Selection Criteria: This was the first international case that I selected, and it was very complex for multiple reasons. First, the ICRC is not a typical software producer, and their technology was used for marginalized communities in extremely critical situations. The ICRC was very open about the incident, providing valuable data for observation. Additionally, there are a variety of regimes that govern their organization and technology, such as the Geneva Conventions, and their relationships are very complex. The complexity of the relationships between the ICRC as a software producer, the various regimes that regulated the use of their software, and the vulnerability of the end-users made this an important case to examine. Overall, this case demonstrated the critical nature of data privacy and security in a unique and challenging way. Furthermore, I came across the case through a subject matter expert, and connected with others, who could provide key internal details beyond

the publicly available information.

Context: The regulatory regimes governing the ICRC are multifaceted, stemming primarily from international humanitarian law and internal self-regulation. The highest legal basis for ICRC's operations are the Geneva Conventions (dating back to 1864 and revised in 1949, with later Additional Protocols), which establish international laws for the humanitarian treatment of conflict and disaster victims, extending protections to their data security and privacy. Furthermore, the ICRC created and adheres to its own stringent internal regulations, such as the ICRC Rules on Personal Data Protection (2015) and the Code of Conduct on Data Protection (2015), designed to ensure its mandate is carried out consistent with internationally recognized standards. These self-regulatory artifacts were developed to maintain the organization's principles of impartiality, independence, and neutrality while operating across multiple jurisdictions and their disparate national requirements.

Antecedent Behavior: The affected beneficiaries, 515,000 victims of armed conflict or disaster, are a particularly vulnerable population who entrusted their sensitive demographic and biographic data to the Restoring Family Links (RFL) program to receive critical humanitarian assistance and protection. They used the software for services like video calling and secure messaging to reconnect with separated family members. However, they would have had the least connection with the software producer and regulators.

The ICRC was seen to be taking a very strict approach to cybersecurity policies and technical controls. However, the breach exploited a known vulnerability in their unpatched software for about 60 days after it was first identified publicly.

Response, Remediation, and Recovery: The diffuse location and vulnerable nature of the beneficiaries disrupted their ability to pursue legal action or compensation. Consequently, the Red Cross Movement often acted as their advocate, making public statements condemning the attackers (although they did not attribute the attack to any actor, as is typical of their focus on neutrality). There is no evidence of compensation being sought by the

end-users or mandated by external regulators. The ICRC was very open about the incident, publishing documentation and even holding an open conference to discuss data privacy in the humanitarian space. They worked with many stakeholders to create new internal regulations to help prevent future cybersecurity issues.

Outcome: The primary cost to beneficiaries was the risk of future harm due to the compromise of highly personal data (health, location, family details). Users may be disinclined to work with the ICRC in the future due to heightened awareness of risks. Some users likely sought to preserve their support by continuing with ICRC, while others may have disengaged to protect their future safety. The organization continues to implement this software and its partners deploy it worldwide, growing their user base since the incident. New controls and policies were implemented afterwards.

4.3 Equifax

Equifax is a US-based credit reporting agency (CRA), one of three in what is called the Consumer Reporting Agency System. The role of a CRA is to collect consumer data that can be used by businesses, such as employers and creditors, as well as government agencies, in their operations. There is a robust regulatory environment surrounding the CRA system, including oversight and enforcement from agencies like the Securities and Exchange Commission (SEC) and FTC, as well as others. The CRA system has a very large role in American society, pulling in data on every consumer in the country, such as their habits and purchases, aggregating them and providing the data to a variety of business customers. In 2017 an attacker accessed and stole the data of 145.5 million consumers in the US, and more in Canada and the UK. There were immediate responses from all stakeholders, including regulatory action, business customer behavior, and, eventually, monetary compensation from Equifax to affected individuals. The scale of the breach, the regulatory

environment in which it occurred, and the aftereffects were widely discussed in the media, academia, and the general public.

The users included passive consumers (nearly every adult in the US) and active business customers (companies and government agencies).

Selection Criteria: This was a major case when it occurred in 2017, demonstrating to the public the vulnerability of their data, and the scale at which it was being collected by data processors, which many people were not aware. In fact, this challenged the definition of a "user," given that many people did not directly, or knowingly, interact with their software. Additionally, Equifax was a highly-regulated organization with strict security and reporting requirements that should have prevented such a massive incident. The conflict was investigated thoroughly by multiple government entities, providing valuable data about Equifax's behaviors before and after the incident, including internal documents and conversations, and testimony from leaders. The public response was also quite broad, adding more resources to understand the impacts of the incident. The enforcement actions after the incident were also sweeping, leading to massive fines and payouts to affected users following major court decisions that set new precedent.

Context: The regulatory regime for CRAs in the US developed over decades in response to concerns regarding the consolidation of sensitive consumer data. Key foundational laws include the Fair Credit Reporting Act (FCRA) of 1970, which was enacted specifically to address the modernizing credit reporting system and requires CRAs to adopt "reasonable procedures" for confidentiality. Subsequent federal laws like the Gramm-Leach-Bliley Act (GLBA) (1999) and the Fair and Accurate Transactions Act (FACT) of 2003 added protections for preventing and correcting identity theft. This body of law, along with corresponding international guidelines and case law established through consistent enforcement actions by agencies like the FTC and Consumer Financial Protection Bureau (CFPB), forms the complex and highly active regime governing CRAs.

Antecedent Behaviors: Passive consumers automatically supplied vast amounts of sensitive financial and personally identifiable information to Equifax through everyday transactions without the ability to opt out. This PII, including names, Social Security numbers, and dates of birth, was compromised for over 145 million consumers. Business customers (including government agencies) actively deployed Equifax's software to inform critical decisions e.g., lending, employment screening. These business users were required to contribute their own customer data back to Equifax in a "give-to-get" scheme. Meanwhile, Equifax suffered from a number of unaddressed vulnerabilities that led to their systems being compromised for 76 days before they were able to identify and remove the threat. The system exploited was a federally mandated customer complaint portal, which had a user-facing website and was connected through complex code to software dating back to the 1970s.

Response, Remediation, and Recovery: Consumers were notified starting in September 2017 and immediately sought remediation by using the ad hoc website created by Equifax (which later suffered from other vulnerabilities) to check if they were affected and enroll in credit monitoring services offered by the company. Consumers engaged in posturing by submitting public comments to regulatory bodies like the FTC and CFPB, advocating for legal corrections and compensation. Crucially, users successfully filed and won a class action lawsuit against Equifax (over $380 million), which was tied together with a separate FTC suit, resulting in legal precedent that regulates the industry.

Outcome: Consumers received significant remedies, including cash payments (up to $125 per filer, and more reimbursement for proven costs) and identity theft protection services from a settlement fund. Equifax executives were required to testify in Congress multiple times about the incident and underwent rigorous investigation and enforcement actions. Business customers that were major clients responded by launching their own investigations, performing security assessments, and modifying contracts to mitigate future

risk. The regulatory landscape, including litigation outcomes, were shaped for the future as a result of this case.

4.4 CatalanGate

In 2022, a political scandal erupted when reports detailed the hacking of prominent people from Catalonia, specifically through their use of the popular mobile/instant messaging software WhatsApp. Catalonia is an autonomous region within Spain, and, in conflict with the interests of the Spanish government, has sought independence throughout modern history. The people affected by the hack include elected officials, political leaders, and activists that were involved in the Catalan independence movement, as well as people associated with them, all of whom were users of WhatsApp. Much of the hacking occurred around the time of the independence referendum in 2017. CatalanGate was part of a broader conflict regarding the use of commercial spyware, in particular one called Pegasus. The scandal implicated a variety of stakeholders, across multiple jurisdictions, in a changing environment. The affected users were Catalan people, who are citizens of Spain, and protected by the recently applied General Data Protection Regulation (GDPR) of the supranational European Union. The software exploited was the popular WhatsApp, developed by an American company with massive reach in Europe, purchased by Facebook in 2014, and now part of the parent conglomerate Meta. Responses to the scandal include multilevel EU enforcement, including a large investigation by a dedicated body, the PEGA Committee and US court decisions in 2025.

The users in the CatalanGate scandal were primarily elected officials, political leaders, activists, and journalists involved in the Catalan independence movement, along with their associated friends and family. The breach of their WhatsApp accounts was found to be perpetrated by the Spanish government for national security purposes.

Selection Criteria: This case was selected because of its setting in Europe, and putative connection to GDPR, which is among the most mature data privacy regulations in the world. Additionally, it involved consumer software, WhatsApp, which I had not investigated previously. The incident was widely covered in the media, and resulted in in-depth investigations by the European government and advocacy organizations, resulting in rich data. Furthermore, the affected users were important figures that were targeted more narrowly than in prior cases. Ultimately, this case became even more valuable because of the complex nature of the European regulations that were implicated. The incident revealed major shortcomings in GDPR, which led to limited enforcement, and pushed regulators to establish new protections. The involvement of Meta, an American company, and its litigation also added valuable data for analysis. Lastly, I studied this case only as it unfolded in Spain, although the full extent of the Pegasus spyware and data privacy disputes occurred in multiple EU member countries, providing a valuable boundary for investigating a broader phenomenon.

Context: The relevant regulatory framework in Europe, particularly the General Data Protection Regulation (GDPR), was developed based on a long history of legal protections for data privacy within EU member states. The expansion and passage of GDPR were driven by key societal changes, including the general growth of the internet and monolithic companies like Facebook and Google, as well as crucial Court of Justice of the European Union (CJEU) decisions like the 2015 *Schrems I* case concerning the transfer of EU data to the US. However, there is a perceived gap in privacy protections when it comes to member states using spyware technology for security. Meanwhile, within Spain, the right to privacy is constitutionally protected under the 1978 Spanish Constitution, although this right can be suspended for national security reasons, provided there is judicial participation and parliamentary control.

Antecedent Behaviors: These users were utilizing WhatsApp ubiquitously for both

personal and official/business communications. Their involvement in political operations, such as the independence referendum in 2017 and subsequent political events (e.g., elections, appointments), made their data highly valuable to potential attackers. The attacks compromised their mobile devices, effectively turning them into sensors for surreptitious surveillance, exposing private information beyond just in-app messages.

Response, Remediation, and Recovery: After the breaches were revealed, targeted users demonstrated significant activism and legal efforts. They engaged in posturing by making public statements to journalists and networking with activist organizations like Citizen Lab and Amnesty International. At the national level, they filed as many as nine complaints in Spanish courts and pursued investigations through the independent Spanish Ombudsman's office. At the international level, affected users participated directly in the European Parliament's PEGA Committee hearings and investigations in an attempt to amend the governing regime. Furthermore, user concerns regarding human rights led to the very rare support of advocacy organizations for Meta in their lawsuit against the spyware creator, NSO Group. This was also successful and novel litigation that set new precedent.

Outcome: In the European regime, the publicity of the scandal led to aggressive investigative activities by the European Parliament, which established the PEGA Committee, resulting in a formal report and non-binding recommendations adopted in 2023. New EU regulations like the Cyber Resilience Act (CRA) and the Media Freedom Act (EMFA), as well as the Pall Mall Process outside of the EU itself, were later introduced to set cybersecurity requirements and add protections against spyware use, but stopped short of restricting state-sponsored spyware deployment. Spanish regulatory authorities largely preserved the existing regime, meaning the users are still seeking meaningful remedies.

4.5 Office of Personnel Management

The United States Office of Personnel Management (OPM) is the primary human resources agency and personnel policy manager for the federal government. Between 2014 and 2015, the OPM suffered from a series of cybersecurity failures that amounted to one of the largest data leaks in US government history. The vulnerability exploits compromised sensitive data for government employees, including information that could be threatening to national security. The exfiltrated data contained personally identifiable information (PII) from over 21 million government employees, including personnel files, detailed information from background security investigations required for security clearances, and biometric fingerprint data. As a government agency, the OPM is highly regulated, particularly by the Federal Information Security Modernization Act (FISMA), and the data it was responsible for was also highly protected.

Breaches in 2014 were identified, but security teams were unable to identify the full extent of the exploits, which led to them persisting through 2015, resulting in a second overall data breach. In response to the incidents there was comprehensive regulatory enforcement, including by the US House of Representatives and federal agencies, as well as a successful class action lawsuit against OPM and its vendor, KeyPoint. OPM provided credit data monitoring for affected victims and reformed their cybersecurity efforts as a result of the incident.

Selection Criteria: This case was selected because it was so high profile, and involved a government software producer that was highly regulated. This case is also distinguished by its dual incidents, which offers two stages of antecedent factors, those that led up to the first breach, and the (failed) responses to it, which then become the precursors that led to the second breach. The investigation by Congress also revealed a wealth of information for analysis, including internal documents, testimony, and conversations from cybersecurity

personnel working on the incidents. Furthermore, the volatility of the data that was compromised demonstrates the critical nature of data security and privacy, and the cooperation required to maintain it.

Context: The context of the OPM breach is characterized by a complex intersection of government operations, high-stakes national security data, and an evolving regulatory regime. OPM managed the Personnel Investigations Processing System (PIPS) on behalf of deployment users, including over 100 federal agencies, for background checks, security clearance data, and more. The end-users were the millions of federal employees and contractors whose data was stored in this system. OPM was governed by the Federal Information Security Modernization Act (FISMA) and overseen by internal watchdogs like the Office of the Inspector General (OIG) and external bodies like Congress and the Office of Management and Budget. Since 2005, federal agencies had been targeted by Advanced Persistent Threats (APTs), which are sophisticated, state-sponsored hackers. OPM was a "prime target" due to the immense value of its centralized PII.

Antecedent Behaviors: Following the Intelligence Reform and Terrorism Prevention Act of 2004 (IRTPA), OPM assumed the responsibility for processing 95% of the government's background investigations. This created a massive backlog, leading leadership to prioritize the speed of processing over the quality of cybersecurity. Much of the data was stored on an antiquated mainframe environment (PIPS) that lacked modern security controls. Furthermore, OPM was cited as one of the weakest agencies in implementing Personal Identity Verification (PIV) cards; as of 2015, only one percent of staff were required to use them. Despite repeated warnings from the OIG starting in 2005, OPM leadership failed to prioritize security. A 2013 audit released just as new Director Katherine Archuleta and CIO Donna Seymour were onboarded revealed security controls that had never even been tested.

Response, Remediation, and Recovery: The response was marked by intense friction

between OPM leadership and regulators. OPM attempted to modernize its architecture but faced bureaucratic hurdles, leading to a second round of breaches after the first had been identified. The House Oversight Committee launched a scathing investigation, accusing OPM leadership of making "misleading statements" regarding the breaches. This eventually led to the resignations of the Director and CIO. Labor unions (AFGE and NTEU) filed a class action lawsuit, which was initially dismissed but overturned on appeal. OPM eventually settled for $63 million in damages for victims.

Outcome: These breaches put cybersecurity in the federal government, and nationwide, in focus. The Obama administration launched a 30-Day Cybersecurity Sprint in June 2015, mandating that agencies immediately implement multifactor authentication and patch critical vulnerabilities. Background investigations were moved from OPM to the Defense Counterintelligence and Security Agency (DCSA) in 2019. Furthermore, the Cybersecurity and Infrastructure Security Agency (CISA) was granted new power to issue Binding Operational Directives to enforce standards across the government. OPM has spent over $725 million on identity theft protection services for victims. For users, the breach created long-term risks for those involved in national security, as their intimate personal histories are now in the hands of a foreign power.

Chapter 5: Grounded Theory

Through multiple rounds of coding and analysis of the case data, I developed a grounded theory of multistakeholder conflict and cooperation in software cybersecurity. Concepts emerged from analysis of within- and between-case data, and were revised through multiple rounds of coding. The theory development process culminated in a lightweight test of the theory through the fifth case analysis. The behaviors and outcomes in each case are described through a model that was developed to support the theory development.

First I will introduce the final working model, which was iterated through the basic and advanced stages of theory development. The model is similar to a predictor-outcome-consequence matrix as described in [60]. The model includes antecedent variables, outcomes, and consequences that can be used to explain, not just describe, patterns in each case. Furthermore, this model can be used to replicate my approach and support my findings, as well as in future research. The model and theory can be applied to similar cases in data privacy and security to support analysis in fields including cybersecurity, conflict analysis, political science, and business. Researchers investigating real-world cases in these areas can use the grounded theory to understand the behaviors of key stakeholders in their research, scope areas of analysis, and account for outcomes they observe. They will have reliable descriptors for behaviors and outcomes for all different stakeholders involved in their cases.

Next, I will introduce the theory and its key findings. Whereas the model frames the data, the theory and findings include analysis that can be used to explain the patterns of

behaviors by the stakeholders, and their outcomes. The findings include the relationships within each case, and how they are related, or not, to the other cases. Ultimately, the theory explains systems associated with engineering software security to improve data privacy, based on the involvement of various stakeholders.

5.1 The Model

I started with a baseline model, presented in the dissertation proposal (Figure 3.2 and earlier in this document, Section **??**), based on preliminary research to help structure the case studies. This was instrumental in identifying and describing multistakeholder conflict in the early stages of my research. However, the baseline model quickly became insufficient to describe the full complexity of even the pilot case. Immediately, new concepts emerged, and the model expanded to include additional phases both before and after the data breach. Across the first four cases I was able to code the data and evolve the model to describe the circumstances and relationships between stakeholders before and after data privacy breaches. In the fifth case, I attempted to use the model without modifications to ensure that it could be applied to future cases. This test case was successful, as the model held up to scrutiny and served as a useful tool to interpret the final case despite choosing the test case to deliberately challenge the model in specific ways. In particular, I attempted to find a case that would stress the GT due to its unique inputs, including the complexity of the incident and its stakeholders, as well as the outcomes, which were somewhat unique.

Anecdotally, the bigger test of the theory was not the final lightweight test case, but instead came when new developments in the pilot case (Illuminate Education) occurred in 2025, nearly five years after the incident occurred and three years after I had conducted my case analysis. This did not challenge the overall model, nor the theory, but impacted cross-case analysis and revealed important behaviors.

5.1.1 Final Model

The final model has seven phases, made up of states, behaviors, and an incident, along with the three groups of stakeholders: users, software producers, and regulators. The phases align with the Grounded Theory coding family known as the six C's: Causes, Context, Conditions, Covariances, Contingencies, and Consequences [40, 86]. The model phases and the coding family are designed to describe the interrelationships between stakeholders, including both how they influence the incident, and how they respond. Ultimately, the model is a functional tool for practitioners and researchers to describe and analyze cybersecurity incidents over time with a focus on the relationships between key stakeholders to the incident. It is a novel contribution to scholarship about conflict and cooperation in cybersecurity and software that can be used in conjunction with other theories, models, and frameworks.

This model is unique from other models and frameworks, such as those referenced in Section 2.4. Software engineering and cybersecurity frameworks typically focus on implementation procedures within an organization, especially technical processes. For example, the popular NIST and SANS frameworks define cycles of behavior before, during, and after incidents for technical and non-technical personnel within an organization. However, they do not include concepts for understanding the other stakeholders in the incident, the relationships between them, nor the behaviors before and after an incident. Policy and international relations models typically describe the broader landscape of cybersecurity, including different stakeholders. However, they typically do not provide concepts for describing stakeholders at different levels of society (such as individuals, companies, and governments), nor their interactions both before and after an incident. My new model provides the concepts necessary to scaffold the investigation of data privacy and security in conjunction with other models and frameworks. It can be used by technical, legal, and lay

stakeholders in practice, as well as for scholarly research.

The final model was expanded from the baseline model and includes additional phases and concepts based on empirical case data. The baseline model was developed primarily based on concepts from the literature, my general knowledge about privacy disputes, and grounded theory concepts. When this was applied to the case data, concepts quickly grew, introducing new concepts that encompassed the behaviors and states of each group of stakeholders, including individual activities, inputs, outputs, and net effects. Codes for the different behaviors and outcomes continued to evolve through the multiple phases of coding. As the model evolved, I used the most current version to analyze the case studies, resulting in some differences in codes in each case analysis, which are included in the appendices. For example, in the baseline model, the "Conflict/Dispute Node" encompassed the Conditions for the conflict. However, it became clear that there were a variety of Conditions that presaged the dispute in the cases, and so the Conditions expanded to include both a "Behavior" phase and a "State" phase, which describe both the actions and outcomes taken by stakeholders prior to the conflict, and which are the Conditions to it. This Behavior-State relationship was also added after the incident, within the Action-Interaction group of codes, to describe the interactions between the stakeholders. The groups of codes within each phase also evolved, subsuming earlier concepts and were deliberately aligned to demonstrate the parallels between the stakeholder groups, in spite of their differences. The Adverse Event/Incident phase also went through multiple transformations, eventually becoming a single inflection point around which the other phases coalesce.

Following the third case study, the model was in a sufficiently mature state, and to begin more advanced cross-case analysis, I introduced value scales to the observed behaviors and states. This meant that in each case, in each phase, and for each set of behaviors and outcomes, I assigned a score such as weak or strong, lenient or strict, passive or active, unfavorable or favorable, etc. These values provided useful data to analyze patterns of

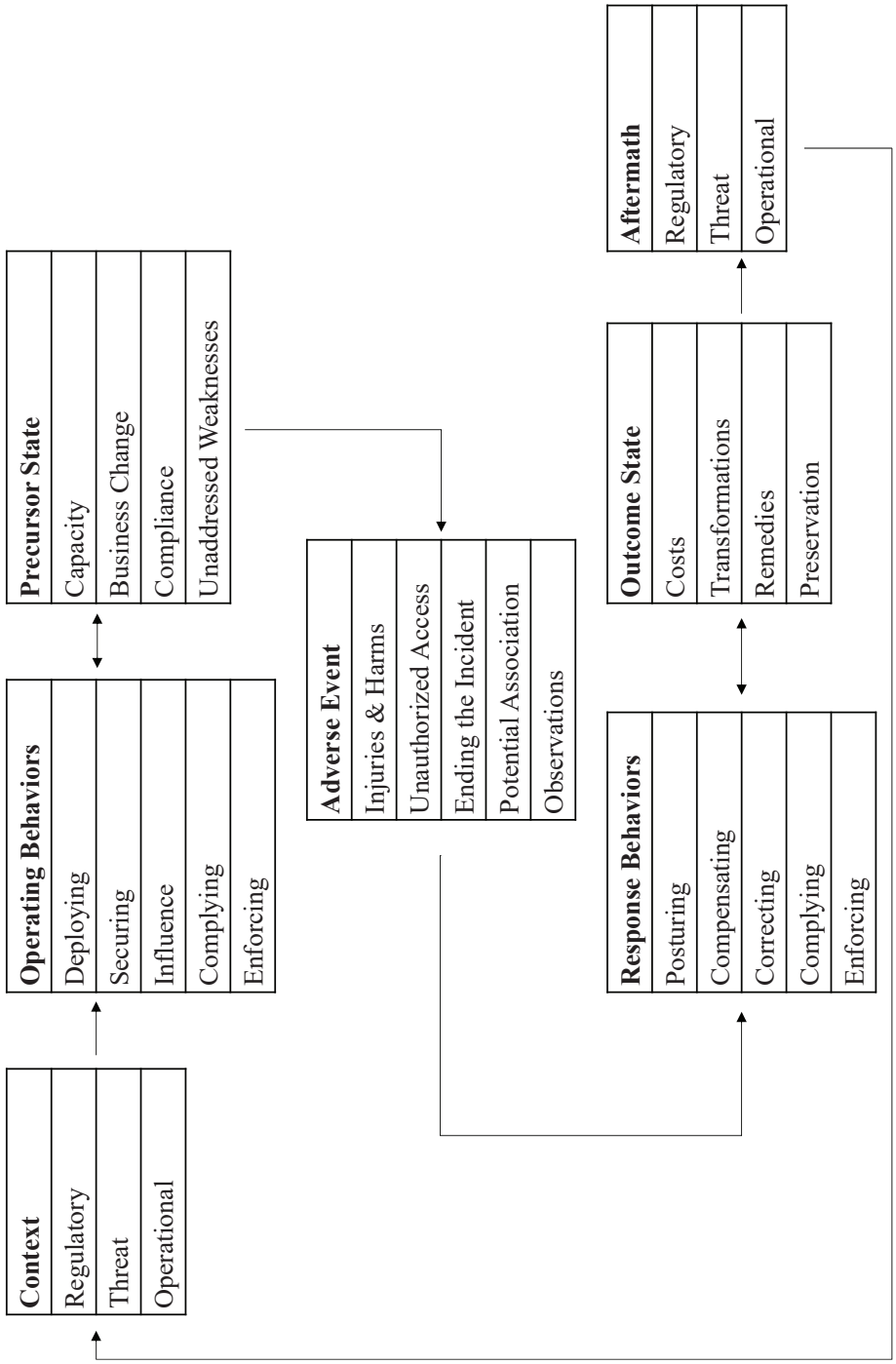

Figure 5.1: Final model behaviors, phases, and states.

behaviors and outcomes between cases and within them. Beyond verbal descriptions, I was now able to evaluate the relative effort behind a given behavior and its relative impact on outcomes. By assessing antecedent characteristics such as a "Strict Regime" or "High Capacity" I was able to account for consequences like "Favorable Remedies" and "High Costs." For the dissertation, I only assigned values for the overall stakeholder group, not for individual actors within it, such as national versus state regulators, although this would be a logical next step. Additionally, using these values took a small step towards quantifying some of the concepts in my work. However, these values could be applied more extensively for more detailed quantitative analysis in future work.

After the fourth case, including all aspects of the model, I was able to test it on the fifth and final, test case. The final case warranted no substantial revisions to the model, and I was readily able to fill in the data I collected. I then continued to analyze the cross-case data using the model, including the value scales, and developed the findings in Section 5.3. Below I will provide an overview of the structure and components of the final model. An overview of the phases, behaviors, and states is shown in Figure 5.1 The full model is available in Appendix **??**.

5.1.2 Model Components

Below is an overview of the major components of the model, including definitions of the key concepts. The full list of definitions is available in Appendix **??**.

Phases The model is made up of two types of phases, behaviors and states, that connect to each other. Behaviors result in states, and states influence behaviors. There are three antecedent phases before the incident: the context state, operating behaviors, and precursor state. Following the incident, there are three consequence phases: the response behaviors, outcome state, and the aftermath. The incident is an inflection point that occurs due to

the antecedent operations and precursors and instigates the responses and outcomes. The context and aftermath act as a start/finish line for each case, where the aftermath may have impacts on the context going forward. The incident is typically perpetrated by a malicious party who is not included as a stakeholder. This has important implications in the model and theory, but the general premise is that there is no continuing relationship with the attacker. Additionally, while the attacker is responsible for introducing the incident, the conflict and cooperation between the stakeholders is the observable area of my inquiry, including what happened between the parties before and after.

Each phase (except for the context) is comprised of net effects that are the results of activities, inputs, and outputs from the stakeholders. The context consists of different environments. In each phase, the net effects and environments are closely related between the stakeholders, and frequently overlap. The overlaps and connections between these net effects demonstrate the interconnectedness of the actions and interests for each stakeholder group. The result is a practical model of conflict and cooperation for multistakeholder data privacy and security. The model is sufficiently broad to allow for future concepts to be extended, but narrow enough to meaningfully describe the system. The phases include behaviors and states that are observable in different cases.

Context The context is the state that exists between software producers, regulators, and users in trying to achieve data privacy and security goals (see Figure 5.1). The concept is based on the grounded theory concept of context, which bounds the case being studied, and represents the zone where the possible (or inevitable) conflict occurs between the triad of users, software producers, and regulators. For the purposes of this research, this space is limited to social conflict with regard to data security & privacy and software engineering.

After a dispute is settled, it may change the global context for future disputes, such as through case law, new regulations, changes to behavior, etc. This is why we can consider

	Context	Operating	Precursors
Users	Regulatory Threat Operational	Deploying Securing Influence Complying	Capacity Business Change Compliance Unaddressed Failures
Software Producers	Regulatory Threat Operational	Implementing Securing Influence Complying	Capacity Business Change Compliance Unaddressed Failures
Regulators	Regulatory Threat Operational	Rulemaking Enforcement Investigation Influence	Regimes Capacity

Table 5.1: Antecedent Conditions: Context, Operating Behaviors, and Precursor States.

the context node a "start/finish line," as a conflict has a starting context, and may eventually have an impact on that context.

The context is comprised of three environments for each stakeholder: regulatory, threat, and operational. These environments are interrelated but have different inputs, outputs, dimensions, and meanings for each stakeholder. The overall context sets the stage for the conditions, actions-interactions, and consequences throughout the case being analyzed.

Operating Behaviors The operating behaviors are the real-world actions taken by the stakeholders preceding the conflict that occurs as a result of a data breach. This phase is the first that establishes the conditions described by GT, and these behaviors yield a precursor state. The operating behaviors follow logically from the context, and describe the various activities taken by stakeholders, which are categorized into a limited set of net effects. Net effects comprise the goals and organizational processes that each stakeholder has in interacting with each other, whether that means using software, creating software, or regulating software.

For users and software producers, the operating behaviors are deploying or implement-

ing, securing, influencing, and adhering/complying. For regulators, they are rulemaking, enforcing, and influencing. Because the operating behaviors are all action-oriented, they can all be evaluated by how active the stakeholder is in that behavior, either active or passive.

Precursor State The precursors comprise the state that stakeholders find themselves in as conditions to a dispute. The precursor state is the outcome of the operating behaviors, and in some ways are an abstract description and in others are a more concrete explanation of the antecedent conditions. Ultimately, they describe the state of affairs that are exploited by malicious actors and which will be under scrutiny after the data breach. There is not a direct timeline from operating behaviors to precursors and stakeholders may cycle between these two phases. For example, business change (a precursor state) may result from deployment activities (operating), which could affect their capacity (precursor).

Adverse Event/Incident The incident is the first step of the action-interaction phase, and represents the behaviors undertaken by the stakeholders as the incident unfolds. The incidents being studied are data breaches caused by malicious actors exploiting a vulnerability and gaining unauthorized access to user data through software producer systems. Activities are almost entirely limited to the software producer during the incident itself, although users are directly affected, and regulators are implicated.

Responding, Recovering, & Remediating Behaviors The behaviors that the stakeholders take after the incident occurs are included in a phase called responding, remediating, and recovering (RRR). For ease, I typically refer to this as the Responding phase, although the other components, remediating and recovering, are also important, and the behaviors contribute to those strategies. The options the stakeholders have at this phase are predicated on the operating and precursors before the incident, as well as the nature of the incident

	Responding	Outcome	Aftermath
Users	Posturing Compensating Correcting Complying	Costs Transformations Remedies Preservation	Regulatory Threat Operational
Software Producers	Posturing Compensating Correcting Complying	Costs Transformations Preservation Remedies	Regulatory Threat Operational
Regulators	Posturing Compensating Correcting/Enforcing Complying	Costs Remedies Transformations Preservation	Regulatory Threat Operational

Table 5.2: Interactions & Consequences.

itself. The range of possible actions, and what actually occur, vary widely and have very different results. There are examples of conflict and cooperation in this phase, and patterns emerge that can change the context for future, similar incidents, or ensure that things stay the same.

The categories of behaviors (the net effects) taken by all stakeholders in the RRR phase are all the same: posturing, compensating, correcting, and complying. The net effects are organized to share the same terms for each stakeholder, showing that they pursue a similar set of goals, although they can have different consequences. Each individual net effect can support response, remediation, and/or recovery efforts, which is why the entire phase uses those three terms, but there is no single net effect that uses any one of them. This is a very active phase, with many intertwining actions, and overlapping efforts.

This cohesive approach holds true when the goals between stakeholders are mutually beneficial, and when they are at odds with each other. The matching categories demonstrate the way that goals between stakeholders can be aligned following a data breach. However, even when interests are opposing, stakeholders are still seeking different goals within the same categories of activities. For example, while all three stakeholders might go to court,

the way they get there, and their intentions for doing so, are not usually the same.

These activities are what grounded theory describes as covariances, as these are the actions and interactions that vary together between the stakeholders, sometimes causally. Stakeholders' actions cycle back and forth as the conflict unfolds, and their behaviors are determined not just by the antecedent conditions, but also by the behaviors of the other stakeholders.

Outcome State The outcomes and consequences are the practical results of the behaviors in the previous phase. Similar to the RRR phase, the possible outcomes are organized into a set of categories that are the same for each stakeholder: costs, transformations, preservation, and remedies. While the individual outcomes within these categories vary for each stakeholder, the categories themselves remain the same, and can represent both the aligned and disparate outcomes for the stakeholders. For example, in determining remedies, the stakeholders might negotiate together (such as in a court settlement) to get the best remedies for themselves, while reducing their own costs.

The consequences are typically focused within the given case they are describing, but those with a larger scope can result in broader changes to the context going forward, which is described in the next phase.

The outcomes have a rich covariance with each other, and with the previous phase. It is difficult to disambiguate many of the outcomes, both for each stakeholder and between stakeholders. For example, costs and remedies are connected, but may not vary directly, as higher costs could mean better remedies, but not necessarily. These correlations and causations have important implications for observing the relationship between the parties, including their cooperation and conflict.

From a theoretical standpoint, by including the same categories for each stakeholder, even when there was little or no data in some cases, it left the door open for future cases

to introduce that data. By creating interconnected categories in advance, it was feasible to assume that future cases could fill in those gaps, instead of limiting the model to what had only been observed.

Aftermath The aftermath describes the changes to the context for similar cases going forward. This means that the case had observable impacts on the regulatory, threat, and operational environments for all stakeholders. Not all cases resulted in an observable aftermath, meaning that not all cases were so critical that they changed the way future cases would be addressed. However, those that did result in such drastic aftermath phases included three observable phenomenon: there were gaps in enforcement mechanisms that were addressed, there were novel approaches to cooperation that had not occurred before, and there was a perceived critical nature of the issues involved in the case. Taken together, these characteristics led to long-term changes to the contexts (regulatory, operational, and threat) of future data security and privacy cases.

5.2 The Theory: Regulate, Recover, Repeat

The theory, *Regulate, Recover, Repeat*, describes the cyclical nature of software cybersecurity, and the roles that people play in that system. In a sense, I am elevating the popular aphorism about data breaches "it's not a matter of *if* a software will be breached, it's a matter of *when*" into an empirically sound theory, and incorporating the different ways that stakeholders address this dilemma. When thinking about cybersecurity, all stakeholders participate in regulation to prepare for an incident, and in recovery after it occurs. Then everyone does it all over again.

Each stakeholder, whether a user, a software producer, a regulator, or someone else, participates in different ways, and the outcomes of their efforts vary. Meanwhile, they may

not be thinking strategically about what the other stakeholders are doing or how they will respond. When the inevitable next incident strikes, sometimes there are new resources in place after the preceding ones, sometimes not. Those resources include technical controls and regulations, but they can also be shared interests and cooperation, or at least a better understanding of the other parties involved. In order to improve cybersecurity, these people must be able to observe and understand each other's behaviors.

Furthermore, there are few resources for holistically explaining the multistakeholder systems of cybersecurity efforts. But such resources can help improve the commercial interests of businesses and consumers, as well as democracy and the public interest. At any point, someone can pick up the model that I have developed and start analyzing cybersecurity incidents to look for strengths, weaknesses, opportunities, and threats across all the stakeholders that are involved. Ideally, they can identify mutual interests between the stakeholders, and capitalize on them to improve data privacy and security.

Below I will further elaborate the theory based on its findings. This includes major themes incorporating the model and between-case conditions and actions that emerged that logically explain the consequences [60].

5.3 Findings

To fully construct the theory, I reduced each case into its component parts within the model. This meant creating 1-3 sentence breakdowns of the behaviors and states based on the full case analysis. I then applied values to each behavior and state based on the value scales described earlier. The result was the Model-Case Matrix, also known as a "predictor-outcome-consequence" matrix, as described by Miles, Huberman, and Saldaña [60]. The full matrix has 275 components, which were color coded for their values for easier pattern recognition. I compared the different values within and between cases in the first four cases

to develop the initial findings. I then coded and applied values to the fifth lightweight test case, and compared the results to the findings.

The full Model-Case Matrix is available in Appendix **??**, and the specific components have been reduced into tables within each finding.

5.4 Finding 1: Regulatory Context Drives Compliance After Incidents

The first finding relates to the Context Environments for the Software Producers and the Regulators in each case. In all five cases, the Threat Environment for Software Producers has been rated as either Risky or Somewhat Risky. This aligns with the nature of the cases I have selected, given that they all suffered high profile data breaches. While Software Producers typically attempted to adhere to the rules, there were lapses in their Operations that led to the breaches. However, after the incident, their relative Complying Behaviors were clearly linked to the factors before it: limitations in the Enforcement or Complying prior to the incident indicated that they would also be less compliant afterwards.

5.4.1 Context & Environments

There is a chicken-and-egg relationship between the Threat Environments and Regulatory Environments. Specifically, the Threat Environments for Software Producers were all rated as Risky or Somewhat Risky. Additionally, the corresponding Regulatory Environment for Regulators, which describes the strictness of the regime in place, were rated as Strict or Somewhat Strict. This reflects a real-world relationship between the regulatory bodies and the software producers where the sensitive data being collected is understood to be at risk for harm to users, and requires regulatory involvement.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
SW Producers Threat Env	R-	R	R	R	R
SW Producers Regulatory Env	N	S	S	S	S
Regulator Regulatory Env	S-	S	S	S-	S-

Table 5.3: Antecedent Context Values for Finding 1. S = Strict, S- = Somewhat Strict, N = Neither Strict Nor Lenient. R = Risky.

Threat Environment

ICRC was rated as Risky for its Threat Environment particularly because of its highly variable threat surface: it operates in multiple countries, each with different technical needs, different regimes governing their use, and different potential attackers. Equifax was rated as Risky because it is such a high value target, and nefarious actors are known to be pursuing advanced tactics to compromise the data. Illuminate Education is considered only Somewhat Risky because the software producer had a slightly more limited threat surface, focusing only on education software, which would have had some valuable personal information, but not as much as the Red Cross or Equifax which deal with particularly sensitive data. WhatsApp (in CatalanGate) can be seen as risky because, while they were familiar with a variety of threats and regularly released security updates, they had such a massive user base that they were probably constantly under threat.

Regulatory Environment

There were similarities between the cases with Risky Threat Environments for Software Producers, and the Regulatory Context in which they operate. Both the Software Producers' Regulatory Environment and the Regulators' Regulatory Environment are considered to be Strict in the ICRC, Equifax, and CatalanGate cases. This means that the Software Producers closely adhered to their regulations, and Regulators strictly enforced them.

The Software Producers' Regulatory Environment is shaped by the regime that governs

them, and how it imposes on their business practices. In a sense, this is about how they interpret the regime created by regulatory stakeholders. In three cases, they were taking strict interpretations: ICRC had multiple national and international regimes to adhere to, and strict endogenous regulations; Equifax complied with a rigorous legal regime that protects the data it collects and stores about US consumers; WhatsApp was highly regulated in Europe, where the breach occurred, under the General Data Protection Regulation (GDPR). In these cases, failure to comply would severely affect their operations. Illuminate Education had a slightly less strict Regulatory Environment, given that there were/are less clear requirements for them to protect their data, and it is more likely that their customers (educational institutions) were responsible for data protection. However, this also depended on the jurisdiction where they operated.

The Regulator's Regulatory Environment is primarily comprised of the regime that emerges from the legal history, court rulings, legislation, national and local governments, etc. In the ICRC case the Strict regime emerges from multiple national and international governing bodies, which provided strict guards on actions, and pre-emptively forced compliance by the Red Cross' software implementation team. For Equifax, the Strict regime emerges from multiple federal agencies with broad mandates and robust enforcement methods, as well as strong protections for the data of consumer Users whose data is being collected. For Illuminate Education, the Somewhat Strict regime emerges from some national and state agencies that have varying enforcement abilities. For CatalanGate, the Somewhat Strict regime rating comes from the fact that while the EU had strict privacy and data security regulations in place, those requirements were mainly focused on consumer technology, and were very limited with regard to spyware. Additionally, Spanish authorities also had a Somewhat Strict regime in place, because although it was rigorous in its requirements for the use of spyware, such as ex ante and ex post documentation of decisions, it still mostly supported the use of spyware by their government.

5.4.2 Compliance Behaviors

Prior to the incident, the ICRC, Equifax, and WhatsApp were active in their Compliance Behaviors (although Equifax suffered some crucial lapses, which affected their actual Compliance State). Additionally, they were rated as High in their Compliance Behaviors in their Responses to the Incident. However, Illuminate Education was comparatively less Active and less Strict in its Compliance before and after the incident. This appears to reinforce the impact of the strict Regulatory Environments in which the companies operate.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
SW Producers Complying Before	N	A	A	A	P
SW Producers Complying After	N	H	H	H	L-

Table 5.4: Antecedent Conditions Finding 1. A = Active, P = Passive. H = High, N = Neither High Nor Low, L- = Somewhat Low.

Antecedent Operating Compliance

ICRC was considered Active in its Compliance operations because it must adhere to a uniquely complex regime designed for catastrophic situations which includes protecting user data, among many other concerns. They have a robust internal bureaucracy for creating and implementing their own policies, guidance, and rules. This was arduously documented. They also deployed software to be compliant with the non-functional, regulatory requirements of their users.

Equifax's Active Compliance was driven by the US government's strict regulations to protect consumer interests, including data collected by Equifax and its competitors. The financial industry and the credit reporting industry also have some self-regulatory bodies to protect their businesses by protecting consumers. As quickly as Equifax began to use computing for business in the 1970s, they also had to implement and maintain software

solutions to comply with regulations, in particular, a dispute resolution platform to respond to consumer complaints. This dispute resolution system is where the breach eventually occurred, decades later, and where they failed to adhere to required security measures. It stands to reason that they inadequately secured this capability given that it did not drive revenue for the company and instead was a cost-center. However, generally speaking, Equifax is active in its Compliance activities.

WhatsApp's parent company Meta was one of the main focuses of the development and implementation of the GDPR protections in Europe (e.g. the Schrems I and II lawsuits) [51] forcing their Active Compliance operations. They were under strict scrutiny, and in order to continue doing business in Europe, they were required to comply, unlike possibly smaller companies which may have been able to fly under the radar.

Illuminate Education would have had to implement technical solutions to comply with the regimes in the various jurisdictions in which they operated, for example, the "strict data agreement" with the NYC DOE. They also voluntarily signed onto the Student Privacy Pledge, an industry self-regulatory body. However, the enforcement capabilities of those bodies varied and Illuminate did not require as strict adherence compared to the other cases. Therefore, their Compliance operations were only rated as Neither Passive Nor Active.

Response Compliance Behaviors

Following the data breaches in each case, the Response Behaviors by software producers aligned with their Operating Behaviors: Red Cross, Equifax, and WhatsApp were highly compliant, and Illuminate was moderate (Neither High nor Low Compliance).

ICRC adhered to its regulations and best practices in this phase, addressing the issues of their Users and remediating the issue as quickly as possible, and eventually supplementing their policies with new security measures. Equifax's adherence activities were extremely

intense, beginning with testimony before congress, working with a government delegated third-party to remediate the issue, reporting on their remediation efforts, and later abiding by court rulings to provide compensation to affected users. WhatsApp were rigorous in their compliance efforts so they could work with regulators to prevent the future threat of the use of spyware against their technology, such as through the court system, as well as with privacy organizations that shared their interest in combating spyware through regime change.

On the other hand, Illuminate had very few required compliance behaviors, save those that were enforceable by their contracts (the NYC DOE for example canceled their agreements with the company). Courts ultimately dismissed complaints against them from Users. However, four years later, they were penalized by state-level regulators and forced to pay fines, as well as submit to new security compliance measures overseen by both state and federal regulators.

5.4.3 Finding

More risky threat environments (e.g. in the ICRC, Whatsapp, and Equifax cases) led to stricter Threat and Regulatory Environments (for both Software Producers and Regulators), which in turn resulted in a system where Software Producers were required to engage in more active compliance and adherence behaviors both before and after the breach.

5.4.4 Testing the Theory

The OPM case, which I used as my test case, is mostly in line with this finding, when considering some key details. Similar to the other cases, there was a Risky Threat Environment for the Software Producer, and a Somewhat Strict Regulator Regulatory Environment to try to mitigate that risk. However, unlike the other cases, the OPM as Software Producer

was Passive in Complying before the Incident, in spite of the Somewhat Strict Regime. This differs from the other cases, but for a very specific reason: For years, government had established cybersecurity guidance and rules for government agencies. This also included mandatory roles within agencies, including CIOs and IGs which also supported a relatively stringent regime. However, this oversight did not translate directly into enforcement abilities, leaving a gap just wide enough to allow OPM to shirk its compliance activities.

Furthermore, the OPM case demonstrates another aspect to this finding. OPM was evaluated to be Passive in Complying before the incident, and Somewhat Low in Complying after. This relationship between the antecedent and outcome Complying Behaviors match the finding to some degree, given that the behaviors were aligned across the conflict timeline, as was demonstrated in the other cases.

5.5 Finding 2: Regulatory Operations Impact User Outcomes

The Operational Context for Regulators sets the stage for their Operating Activities and Precursors. This also had impacts on the Remedies for Users after the incident. A Strong Operational Environment means that Regulators are effective in areas like rulemaking, enforcement, and influence, resulting in Strict regimes and Strong Capacity. In the Equifax breach case study, this Strong Environment exists, and there was a Somewhat Strong Environment in CatalanGate. In the other two cases, Illuminate Education and ICRC, the Regulator's Operational Environments were Somewhat Weak. The Operational Environment for Regulators has a clear impact on their Behaviors after the incident, as well as on the Outcomes of the Incident for Users, including better Remedies for Users when Regulators were more effective.

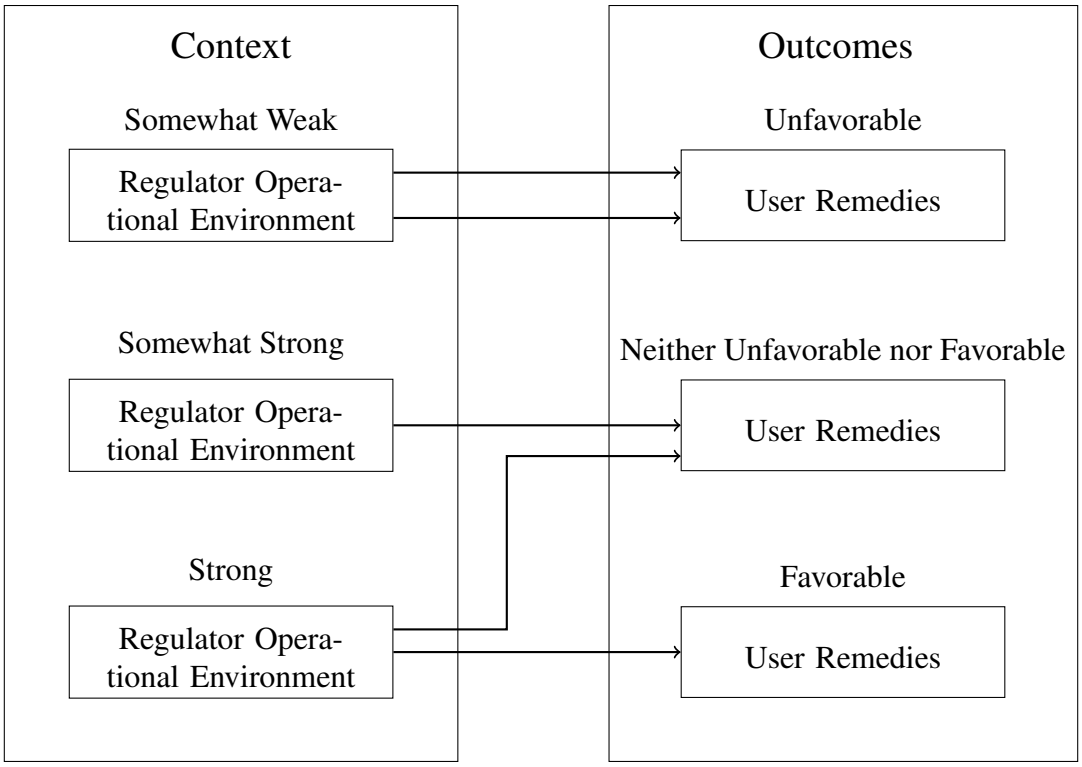

Figure 5.2: Context Impact on User Outcomes

5.5.1 Stronger Regulatory Operational Environments

In the Equifax case, the Regulatory stakeholders have strong operational abilities such as balancing business interests with data security restrictions, enforcement methods, and an effective hierarchy of agencies (limited gaps or overlaps in jurisdiction). Many enforcement methods are regularly employed, and can balance business interests with consumer protections. The political climate of the last 50+ years has frequently favored protecting consumer interests in the financial space. This is true for various regimes including the US, Canada, and the UK.

This Environment yields Active Behaviors including rulemaking, enforcement, investigation, and influence. Strict rules regulating the credit reporting industry rose as quickly as the industry itself did, stemming from case and statutory law, with the input of politicians,

consumers, advocacy groups, industry groups, lawyers, and judges. Rules continued to evolve, adapting to societal changes, with updates in likely every decade since 1970. Enforcement practices were commensurate with rulemaking, agencies (especially the FTC) and courts take action against Equifax and other credit agencies for violations frequently. Investigation is used both before enforcement action and after and CRAs like Equifax are under constant scrutiny by elected officials, agency bureaucrats, and advocacy organizations. The actions of the various regulators stand out as strong influence to encourage Equifax to adhere to rules, signaling their intentions, and shaping the regime. Successful enforcement actions promote the interests of regulatory agencies by publicly showcasing their abilities, and bringing in revenue in the form of fines.

These Operating Behaviors yield Strict Regimes, and Strong Capacity. The Regime that governs Equifax is robust, well-defined, and frequently employed against software producers. The FTC was active in enforcing cybersecurity, privacy, and other regulations against Equifax and similar companies prior to the incident. It had resources, experience, authority, knowledge, support, and funding to pursue violators.

Because there are some Outcomes of the Strong Environment that are not consistent with the Outcomes of the Weak Regulatory Environment, there are some corollaries we can establish by contrasting them.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
Regulator Operational Env	W-	W-	S	S-	S
Regulator Costs	N	N	H	H	H
User Remedies	U	U	F	N	N

Table 5.5: Regulator Operational Environment and User Remedies. W = Weak, W- = Somewhat Weak, S = Strong, S- = Somewhat Strong. H = High, N = Neither Low Nor High. U = Unfavorable, N = Neither Unfavorable Nor Favorable, F = Favorable.

5.5.2 Weaker Regulatory Operational Environment

In the Illuminate Education and ICRC cases, the Operational Environment for the Regulators is considered to be Somewhat Weak. This is true even though the Regulatory Environment for the Regulators is actually seen to be Strict or Somewhat Strict. The distinction lies in the Enforcement Behaviors of regulatory agencies, and their Capacity. They may be able to make rules (i.e. a Strict Regulatory Environment), but they have a hard time enforcing them, or using them to push for favorable outcomes for the people they are supposed to protect (i.e. a Somewhat Weak Operational Environment).

The impact of the Weaker Regulatory Operational Environment is that Enforcement is Somewhat Passive. For Illuminate Education, the regulations appear to provide various responsible agencies with a variety of enforcement mechanisms should a conflict occur, however they do not seem to have been used for data breaches in education technology. For ICRC, Enforcement methods against ICRC and its National Societies are limited. If they upset their host countries or other actors, they may not be allowed to operate. If they lose the trust of their beneficiaries, they may cease to be users. But there do not seem to be any prior cases regarding data breaches where this occurred. For both cases, the Capacity of Regulatory agencies to enforce data privacy and security rules is extremely limited; there is little, if any, documentation of dedicated resources prior to these cases. However, this changed in 2025 when state regulators formed a new partnership to pursue violations of state-level data privacy regulations, including in edtech, and specifically against Illuminate Education.

5.5.3 Impacts on User Outcomes

Within the two cases with Weak Regulatory Operational Environments, there are related Outcomes that contrast with more Strong Environments. Additionally, the Outcomes in the

Equifax case are notable compared to other cases with Strong Environments, and the data from this case can be compared to others to provide reasonable predictions for other, similar cases.

Favorable User Remedies & High Regulator Costs

The most clear correlations in Outcomes are in the User Remedies and the Regulator Costs. For the Equifax case, with a Strong Regulatory Context, the Remedies for Users can be seen as Favorable. Users received compensation from the court settlement, typically up to $125, with protection for up to $20k if there were additional, direct harms. Users also received free privacy monitoring services. At the same time, the Regulators poured immense resources into regulatory actions including ongoing investigation and multifaceted enforcement from multiple agencies, including the legislative and judicial branches in the US, and regulatory bodies in Canada and the UK. These Outcomes seem to flow directly from the Strong Operational Environment.

Unfavorable Remedies & Low Regulator Costs

On the contrary, for Illuminate Education and ICRC, the Remedies for Users were both Unfavorable: no compensation was collected in either case. Simultaneously, costs to Regulators were moderate (Neither Low nor High). Some resources were spent by state regulators to investigate Illuminate, but no major costs were incurred for enforcement or remediation. The Red Cross Movement spent limited resources on remediating the incident and establishing new processes. Once again, there is a clear correlation between the antecedent context and the consequences.

Note: Impact of User Posturing or Compensating Behaviors Between the two cases with Unfavorable Remedies, contrasting methods were employed by Users in Posturing and Compensating, demonstrating that these methods likely did not have an impact on the Outcomes.

In Illuminate Education, parents of affected students were Active in Compensating Behaviors by suing in court. This happened multiple times and eventually all the cases were consolidated into a class action, which ultimately failed. Affected users were also Active in Posturing by speaking out publicly, connecting with advocacy groups who also made statements. At the other end of the spectrum, ICRC Users were completely passive, partly by nature of their situation. They took no action to Compensate nor Posture. Regardless of either extreme in Behavior, the resulting Remedies for Users was the same: none. This helps confirm that Favorable Remedies for Users are highly connected to the Regulatory Operational Context that precedes the data breach, not the actions of the Users.

5.5.4 Finding

The data indicates a correlation between the Context surrounding the cases before the incident and the Outcomes for the people affected by it. A Strong Environment for Regulator Operations, including capacity, enforcement, and investigation directly correlated to positive remedies for Users. Inversely, a Somewhat Weak Environment led to unfavorable outcomes for users. This correlation held despite differences in User activities, such as Compensating and Posturing behaviors, leading to the conclusion that User efforts alone have little effect on User outcomes.

5.5.5 Testing the Theory

The OPM case supports this finding, given that the Strong Regulator Operational En-

vironment led to High Costs to the Regulators after the Incident, and moderately favorable outcomes for Users afterwards.

5.6 Finding 3: Capacity Does Limit User Response, Remediation, and Recovery

The Capacity of Users before an incident describes their abilities to help secure their data, as well as the resources they have available to respond to data breaches if and when they occur. The data indicates that this antecedent Capacity was not usually an indicator of whether or not Users used Posturing as a Response, meaning they were able to raise their concerns in some cases, even when they had limited resources at the outset of the incident. Additionally, they were able to pursue Compensating behaviors after the incident to try and receive some remedies for their harms.

5.6.1 Precursor Capacity

Prior to the breaches in Illuminate Education, Equifax, and CatalanGate, end users were only loosely affiliated, and are seen to have moderate Capacity (or Low, in the case of Equifax) to support data security with their respective software, and protect themselves before and after breaches. In the ICRC case, Users also had limited Capacity, but the case is so different from the others, it is difficult to find a connection between the Response efforts.

The User Capacity in the CatalanGate case stems from Operating Influence Behavior by activist organizations, who were very active in their field, creating opportunity for regime change in the future.

Responses

Despite the limited Capacity of end Users before the Incidents in Illuminate, and Equifax, the Responses afterward were Active. In each of these cases, Users were Active in their Posturing and Compensating efforts in particular. Affected users spoke out publicly about the breach. They connected with legal teams for lawsuits, and advocates for support, who also made statements. Parents of affected students also sued Illuminate in court for compensation, and unsuccessfully attempted to find legal grounds to sue. Equifax users were successful in their legal efforts after a large campaign.

However, in CatalanGate, there was an active network of advocacy organizations that worked together to protect high risk targets for spyware, and this resulted in a uniquely Active Correcting Response in an effort to change the regulations in place. So, while Users were less Active in pursuing compensation in the courts, their activist representatives were diligent in attempting to create new protections for the future.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
User Capacity	N	L-	L	N	N
User Posturing	A	P	A	A	A
User Compensating	A	P	A	A-	A
User Correcting	A-	A-	P	A	P
User Complying	P-	P	P-	N	–

Table 5.6: Finding 3: User Capacity and Responses. N = Neither Low Nor High, L = Low, L- = Somewhat Low. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive. N = Neither Passive Nor Active. - = No Data Available

Finding

This indicates that Precursor Capacity is not a determinant of Users ability to speak out publicly about an incident that affects them, nor seek meaningful compensation. Following a breach, Users are able to find resources to help them pursue remediation. For example,

in the Equifax case, while there are many consumer advocacy groups, the generic nature of their work coupled with the massive number of affected users did not add any Capacity prior to the incident. However, they were able to pursue an historic lawsuit against the company with legal support and in conjunction with regulatory enforcement. In regard to the Illuminate Education breach, the end users, who were primarily made up of students, had little capacity to address their security or protect their interests after a breach. However, the subject matter expert interviewed indicated that it was likely the parents of affected students in wealthy areas that were able to pursue legal action, particularly those who had legal training themselves.

Note: The only confounding factor to this finding was the ICRC case, in which end users had limited Capacity similar to the other cases, but they did not pursue Compensation or make any observable Posturing efforts. The unique nature of this case, which involved highly vulnerable populations in critical situations, such as disaster and conflict, makes it an outlier in this Finding. Their experiences, along with their diffuse geographic locations, made them even more limited in their ability to respond. Furthermore, the ICRC provides humanitarian services that they may have wanted to continue using, without other options, despite the incident.

5.6.2 Testing the Theory

The OPM case supports this finding, as it was very similar to the other cases. Prior to the breaches, OPM, as in Illuminate Education and CatalanGate, end users were only loosely affiliated, and are seen to have moderate Capacity to support data security. The Responses afterward were similarly Active, as Users were Active in their Posturing and Compensating efforts in particular.

5.7 Finding 4: User Responses Impact Costs, but not Necessarily Remedies

Finding 4 concerns the drivers and impacts of User Responses to the breaches, specifically Posturing and Compensating. Posturing and Compensating behaviors had only one clear impact, an increase in Costs to Users. However, those efforts did not necessarily improve Remedies.

5.7.1 Active Posturing & Compensating Response

In the Illuminate Education and Equifax cases, Users' Response to the Breach is seen as Active for both Posturing and Compensating. The Behaviors in each of these cases at this stage resemble each other quite a lot. The cohorts of Users suffered from privacy violations by American organizations in industries that are perceived to be regulated because of the sensitive, and high risk nature of the data. After the breach, in these cases, Users formed networks with advocacy groups and lawyers, made public statements, and filed lawsuits against the software producers. All sets of complaints were consolidated into class action lawsuits in national courts. However, the Remedies varied widely between each case.

In CatalanGate, by comparison, the Posturing was Active, but the Compensating was only Somewhat Active. This is demonstrated by a lack of major lawsuits by the affected users, which changed the Outcomes for users in that case.

Outcome Costs and Remedies

In Illuminate and Equifax, Users hired lawyers to represent them in court, which incurred Costs to them. In consumer class action lawsuits it is most likely that the lawyers incurred the costs without the Users paying anything. So, while affected Users did not in-

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
User Posturing	A	P	A	A	A
User Compensating	A	P	A	A-	A
User Costs	U	N	U-	U	U-
User Remedies	U	U	F	N	N

Table 5.7: Finding 4: User Responses and Outcomes. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive. U = Unfavorable, U- = Somewhat Unfavorable N = Neither Unfavorable Nor Favorable, F = Favorable

cur much monetary costs, they did spend time and energy pursuing the case. Only the legal teams that formed a network with the User group that took on substantial Costs to pursue Compensation for their clients, and ultimately themselves.

In Illuminate Ed, the lawyers representing the Users incurred Costs, but received no Compensation for their work. This means that both the Users and their legal representation would have spent greatly but not received favorable compensation for their efforts.

For winning the Equifax case, lawyers in that suit collected around $80 million in fees, which came out of the total settlement for the affected users in the US. So, while the Compensation for affected Users in the Equifax breach received a Favorable compensation, they still had Somewhat Unfavorable Costs to get it. Additionally, while Users filed in court in the Equifax case, FTC regulators also filed suits against Equifax, and won that suit as well. In principle, Equifax did not pay twice as much for losing twice, but both losing decisions reinforced each other. One could ask the question of whether it was worth it for the Users to incur their own costs if the regulators were going to win is an open question. If lawyers representing the class action did not receive fees for winning, then an additional $80 million may have been available to affected Users. Per Finding 5.5, if there is a clear path to regulatory enforcement, Users may want to ask themselves this question before pursuing legal action. However, it is reasonable to assume that the regulators may not have been able to pursue effective Compensation for consumers, and lawyers representing the lawsuit would have insight into whether a consumer class action lawsuit could possibly

result in better Remedies for affected Users. This can also vary by jurisdiction, but is similar in Canada and US, although different in the UK.

In CatalanGate, Responses by advocacy groups were focused on Correcting Activities to amend the regime going forward. The result is that the Remedies for Users were Neither Favorable Nor Unfavorable, because going forward they may enjoy better protections, but not at this point. The costs for users were also considered High because many of them suffered direct harms, professional and personal, from the breaches.

5.7.2 Note: Passive Posturing & Compensating Response

In the ICRC case, Users were Passive in their Posturing and Compensating responses. In essence, there does not appear to be any action taken. In particular, there were no efforts by Users to Compensate themselves for the breach. Furthermore, the Red Cross Movement, including the internal customers of the software, made few public statements that could be seen as Posturing. This is largely because of their need to stay neutral in international conflict, condemning a presumed actor could impact their ability to support their beneficiaries in the future.

So, while the Remedies in the ICRC breach are seen as Unfavorable, the Costs were mitigated by not expending resources on Posturing and Compensating. Only the Costs associated with the direct impacts of the Incident are present.

5.7.3 Finding

The idea that, when Users expend resources, they can be successful at getting Compensation, is not necessarily true. Spending resources in an attempt to receive Compensation for the data breach was a losing endeavor for the end Users in the Illuminate Education breach, even after new action by regulators years later, demonstrating that there must be

careful consideration before pursuing action. Furthermore, this finding reinforces the factors in Finding 2, that Regulatory Operations have a more measurable impact on User Outcomes, rather than User Response Behaviors.

5.7.4 Testing the Theory

In OPM, this finding was supported. The users were represented by their unions, who would have been responsible for the costs associated with litigation. Furthermore, this type of protective action is what unions are supposed to do with their funds, so the direct costs to consumers were minimal, aside from their already-committed dues. However, because we also measure Costs to include the harms done as a result of the breach, the OPM users were at higher risk to abuse of their data, because of things like security background information, so their Costs were evaluated to be Somewhat Unfavorable. Additionally, despite efforts by unions to improve the Outcomes for Users, they still did not receive Favorable or even Somewhat Favorable Remedies.

5.8 Finding 5: Correcting Activities and Their Outcomes

Correcting activities in response to incidents were carried out by all stakeholders in most cases, but the most impactful efforts were those by Regulators and Software Producers. For User Remedies, the best outcome was achieved when both Regulators and Software Producers were Active in their Correcting Behaviors (synonymous with Enforcing for Regulators), specifically in the Equifax case. However, this relationship was not a sufficient condition for the best Remedies for Users. When Software Producers and Regulators were more Active, but there were not great outcomes for Users, this typically correlated with High Transformations.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
SW Producer Correcting	P-	A	A	A	N
Regulator Correcting	A	A-	A	A	A
Regulator Remedies	U	N	U-	U	U-
User Remedies	U	U	F	N	N

Table 5.8: Finding 5: Regulator Correcting/Enforcing and User Outcomes. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive, N = Neither Passive Nor Active. U = Unfavorable, U- = Somewhat Unfavorable N = Neither Unfavorable Nor Favorable, F = Favorable

5.8.1 Favorable User Remedies

Correcting Behaviors were often undertaken by both regulators and software producers. Regulators in particular were always typically Active or Somewhat Active in some way. In the Equifax case, both the Software Producer and Regulators were Active in their Correcting Activities, leading to optimal results. Equifax undertook much of this activity on its own volition, but some was also mandated by Regulators. These behaviors are also connected to Finding 2, and here there is a connection between the Behaviors after the Incident, in addition to the Context before it.

In response to the breach of Equifax, multiple regulatory agencies took multiple actions, resulting in Regulator Remedies that are considered to be Strong. Enforcement actions (Remedies) included investigation, fines, mandated compensation, ongoing monitoring, and engaging with networks to achieve these goals. The company itself had to restore software, change business processes (including firing staff), and dedicate massive resources to making fixes. They also worked with an external cybersecurity company that reported to the Regulators. This also had the Outcome of Unfavorable Costs for Equifax, which paid dearly for all of these Activities, and ultimately in the settlement with affected Users.

In the Equifax case, Active Correcting Activities by both the Regulators and Software Producer led to Strong Remedies enforced by Regulators. This in turn yielded the only

case with Favorable Remedies for Users. Users received compensation from the court settlement, typically up to $125, with protection for up to $20k. They also received free privacy monitoring services. Regulators also fined the company, resulting in revenue for themselves.

5.8.2 Less Favorable User Remedies

In Illuminate Education, Regulators took very few Correcting Actions against the company, despite state Regulators becoming heavily involved. The result was that Users had Unfavorable Remedies. In CatalanGate, while the Software Producer and Regulators were Active in Correcting Activities, they did not take action in favor of Users, resulting in less Favorable Outcomes for them. In the OPM case, Regulators were Active in Correcting Activities, but once again, the Software Producer was not, and ultimately Users received less Favorable Outcomes than in Equifax. It is worth noting that there was a successful lawsuit against OPM, but Users did not receive the same level of payout as in Equifax.

In Illuminate Education, government regulators initially took very few Corrective or Enforcement actions in response to the Incident. At the national level there was little activity, but some school districts (like NYC) did enforce the terms of contracts with customers by canceling contracts. An industry association also removed the company from its program. Simultaneously, Illuminate Education took little action after the incident, remaining silent publicly, sealing court documents, and making no public effort to resolve issues with the affected Users. However, in 2025, a new partnership of state regulators pursued Correcting activities against Illuminate Education in a novel effort to enforce privacy regulations, eventually fining them $5.1 million. Regardless of this regulatory action, Court Regulators did not find in favor of the Users in the class action lawsuit against Illuminate Education, saving the company from paying millions of dollars in Compensation. Further-

more, the fines levied by the state Regulators were not part of any Remedies paid to Users. Altogether, this reflects Unfavorable Compensation for Users.

The ICRC case in this finding is somewhat of an outlier. As the end users had little Capacity to seek any form of Remedies, and because there was no direct involvement by Government Regulators in particular, the User Outcomes were Unfavorable. Although the ICRC as Software Producer and internal Regulators were Active and Somewhat Active, respectively, this did not translate into Remedies specifically for their end Users.

In the CatalanGate case, Regulators and Software Producers were active, but mainly in an effort to solve problems they saw in the regulations. For WhatsApp, that meant seeking Compensation from NSO Group in US Courts. For European Regulators, this meant investigating NSO Group, then pursuing new regulations to protect Users going forward. Within Spain, the Court Regulators have not been sympathetic to the lawsuits of the Users, finding that the breaches were justified legally. This has resulted in less than Favorable Remedies for Users.

5.8.3 Transformation as an Outcome

Transformations describe changes such as new processes, networks, or policy changes that arise following an incident. These can be limited to the stakeholders in the case, but some Transformations extend beyond the case itself and set new precedent for future conflicts. In the three cases above, there were Regulator Correcting Behaviors that were considered Active. In these cases, instead of better outcomes for Users, there was a higher degree of Transformations observed. Whereas in the Equifax case, Remedies for Users were the best, but there was little Transformation.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
Regulator Enforcing	A	A-	A	A	A
Regulator Transformation	H	L-	L	H-	H-
Regulator Preservation	N	H-	H	H-	H-

Table 5.9: Finding 5: Regulator Correcting and Transformation Outcomes. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive, N = Neither Passive Nor Active. H = High, H- = Somewhat High, L = Low, L- = Somewhat Low, N = Neither Low Nor High

5.8.4 Favorable User Remedies

A novel approach to Correcting Behaviors by Regulators in the Illuminate Education case resulted in important Transformations to the regime, although it did not have drastic benefits for Users. Specifically, a new partnership was formed between multiple state Attorneys General to pursue legal action for data privacy violations, and Illuminate Education was their first target. This new state-level enforcement sets the stage for new approaches to regulatory enforcement going forward, as the Regulators determined they did not have the right tools to enforce data privacy protections for students and children. However, the federal enforcement changed little, and at the national level, the regime would be characterized by Somewhat High Preservation for Regulators, meaning that the national regime remained predominantly intact.

In the Equifax case, Active Correcting Activities by Regulators had a unique correlation with the Transformations and Preservation of their Operations following the Incident. The Outcome was that no major Transformations occurred, and there was High Preservation. Due to the effectiveness of the existing regime, Regulators preserved their mandate, showing that it is effective and can respond to issues without major changes. In essence, they demonstrated that future cybersecurity Incidents would be handled in the same way. This could be connected to the fact that millions of consumers were able to claim compensation, and major fines were levied.

In the CatalanGate case, Regulators, as well as the other stakeholders, worked aggressively on Correcting Activities that were focused on reforming regulations. These Response activities ultimately led to Transformations for Regulators, including new laws that protect these Users going forward, such as the EMFA and ECRA.

5.8.5 Finding

Correcting Activities had different Outcomes. When both Software Producers and Regulators took more Corrective actions, Users benefited through better Remedies, such as in Equifax. When Regulators were Active in Correcting, there was also the opportunity for Transformation, particularly when there was a perceived gap in the regime, such as in Illuminate Education, CatalanGate, and OPM.

5.8.6 Testing the Theory

The OPM case supported this finding. In the test case, Regulators were Active in Correcting Behavior, including enforcement actions and finding in favor of the plaintiffs in their lawsuit against OPM. However, the Outcomes for Users are considered Neither Unfavorable Nor Favorable because the amount of money they received as a result of the suit, and the number of people who were able to make claims, was extremely limited.

With regard to the Transformation Outcomes, following the OPM data breach, Regulators heavily reformed cybersecurity regulations for federal agencies, moved the Software Producer responsibility out of OPM's hand, and forced a change in leadership at the agency. While Regulators had attempted to improve cybersecurity efforts in government and nationwide previously, the OPM breach revealed shortcomings that needed to be addressed. These were major Transformations both in the regime, and for the Software Producer itself.

5.9 Finding 6: Regulator Precursors were a Determinant of their Responses and Outcomes

The strength of the Capacity of the Regulators, and the strength of the Regime before each Incident directly correlated with the Complying Response Behavior as well as the Remedy Outcomes after each Incident. However, some level of Preservation was a common Outcome for Regulators across all Capacities and Regimes.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
Regulator Capacity	W	N	S	S	S-
Regulator Complying	A-	N	A	A	A
Regulator Remedies	N	N	S	S	S

Table 5.10: Finding 6: Regulator Capacity and Outcomes. W = Weak, N = Neither Weak Nor Strong, S = Strong. A = Active, A- = Somewhat Active. S = Strong, N = Neither Weak Nor Strong.

5.9.1 Stricter Regimes and Strong Capacity

In the Equifax case, Regulator Capacity was Strong, as the FTC was active in enforcing regulations against Equifax and similar companies. It had resources, experience, authority, knowledge, support, and funding to pursue violators. Additionally, the regime was Strict, well-defined, and frequently employed against software producers similar to Equifax. This resulted in various agencies Complying with their mandates in taking actions: pursuing compensation, conducting investigations, making legal decisions. Remedies included enforcement actions like investigation, fines, mandated compensation, ongoing monitoring, and engaging with networks to enforce the Strict Regime. Ultimately, Regulators Preserved their mandate, showing that it is effective and can respond to issues governed by the regime.

In CatalanGate, the European and Spanish governments had Strong Capacity to handle data privacy and security incidents concerning consumer companies like WhatsApp,

and had demonstrated their abilities regularly. However, the Regimes can only be considered Somewhat Strict because of the limited rules for incidents resulting from the use of spyware. In Spain particularly, the Regime favored the government agencies responsible for deploying spyware in situations concerning national security. Compliance Responses by Regulators were very active, including thorough investigations by both EU and Spanish authorities. The Preservation Outcomes for this case are only considered Somewhat High because there were calls for regulatory change, and some new regulations have made progress in transforming the Regime, including the Pall Mall Process and the European Media Freedom Act. However, these are not rigorous Transformations to the existing regimes, but stepwise additions to protections, and the existing Regime remains largely unchanged.

5.9.2 Weak Capacity and Somewhat Active Rulemaking

In the Illuminate Education case, the emergent Regime was more Lenient than Strict in enforcing student data privacy regulations prior to the incident, especially against third-party Software Producers. Although they appear to have strict regulations in place for students, regulators actually had limited Capacity to enforce the law in data breach situations. As a result, in Response to the Incident, Regulators initially followed the Lenient regime that was in place, canceling agreements in some jurisdictions, but taking little further action, and not upholding the claims of the User plaintiffs in court. Illuminate Education was not governed as strictly as the education bodies it served would be if they had instead been breached. However, new precedent was set when state level regulators introduced new methods of enforcement against companies that violate data privacy regulations, increasing their Capacity going forward. This is likely due to the Somewhat Active Rulemaking Operations prior to the incident, which paved the way for Somewhat High Transformation and improved Remedies for the Regulators themselves.

5.9.3 Finding

This comparison between the antecedent characteristics of Regulators helps to demonstrate the usefulness of the model in describing their behaviors after the incident, as well as some of the results. Less effective Regulators, typified by Lenient Regimes and Weak Capacity, limited their ability to protect users that suffered a data breach. However, when coupled with more Active Rulemaking Behaviors, and a compelling interest to protect critical data, such as that of students, Regulators were able to Transform the Regulations, and set new precedent. Meanwhile, Stricter Regimes and Stronger Capacity meant the Regulators could take more action immediately after an incident, and this demonstrated their effectiveness, which also allowed them to Preserve the extant regulatory situation.

5.9.4 Testing the Theory

The OPM test case supports this finding, with Strong Capacity before, and Active Complying and strong Remedies after. In the OPM case, for years, the US government had established cybersecurity guidance and rules for government agencies, as well as providing resources to support such efforts. They also required the existence of CIOs and IGs within agencies, which supported Regulatory Capacity, and supported a more Strict regime. Furthermore, the government had enormous capacity to address potential cybersecurity failures and to ensure compliance by their agencies. However, some enforcement capacity, which was added later through CISA, was lacking at the time of the OPM breaches. After the breach, Regulator Remedies included a strong incentive to address the issues that led to the breach, mainly by improving security standards, but also in providing remedies to victims. Additionally, Regulation and enforcement were improved, and new precedence was set in dealing with these issues, demonstrating some Transformation. But overall, the roles of Regulators and the rules stayed the same, with some new enhancements.

Chapter 6: Discussion

The objective of the grounded theory was to answer three research questions, reiterated below. The theory and model can be applied to a variety of situations in data privacy and security, and by any stakeholder. I will discuss the "when" and "how" of these applications in this section, as well as further implications for my results, including relationship to the literature and limitations.

RQ1: What are the types of conflicts that occur between stakeholders related to software security?

RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security?

RQ3: How can cooperation between these stakeholders be facilitated?

6.1 RQ1: What are the types of conflicts that occur between stakeholders related to software security?

As described in the introduction, and my proposal, there are a lot of conflicts that can occur between stakeholders related to software security. In this dissertation, I have focused on social conflict in the area of data privacy and security in software engineering.

Through empirical analysis of real-world cases, I investigated the conflict and cooperation that occurs between stakeholders before and after a cybersecurity incident.

An incident itself presents a conflict that helps set the conditions for cases to be studied. In each case, a software producer suffered unauthorized access to data that they were expected to secure. They were expected to secure this data by their users and by regulators. In these incidents, the software producers, users, and regulators are stakeholders, and because they have interests that do not align with unauthorized access to the data, they are in conflict. The composition of the stakeholders, as well as their interests, responsibilities, rights, and powers vary by case. This is also true for their relationships, approaches to addressing the conflict, and the results of their efforts. However, there are patterns in these characteristics and behaviors, and I have described them in my grounded theory.

The software producers in these cases provide various services for their users, which include business customers, free users, people in need, passive participants, and others. Ultimately, the software producers were entrusted with the data they collected from their users, no matter how they interacted with the software. This trust was codified and enforced by regulators who established binding and nonbinding requirements to secure the data being collected, and protect the people who used the software. These regulations, rules, requirements, and laws were developed over time, based on the changing nature of technology and society. Regulators took into account the interests of the software producers and the users to create these requirements. Users and software producers rely on these requirements for their protection, and to understand what their rights and responsibilities are when it comes to data privacy and security. When a cybersecurity incident occurs, all of these parties are stakeholders to the incident, and they are in need of conflict management to address the problems that arise, and find solutions.

The software producers and users can both suffer harms because of cybersecurity incidents. Users can have financial issues, human security problems, and emotional distress,

among other things. Software producers can suffer from reputational harm, loss of revenue, fines, and negative impacts on employees. My model demonstrates that while software producers, users, and regulators may be in conflict due to the risk and realization of cyber incidents, they also have some aligned interests in finding the best outcomes to solve these problems.

6.2 RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security?

Through my model and theory, I have described the patterns of behaviors and their outcomes by stakeholders when attempting to manage conflicts in software security.

One component of my analysis is the matter of time. "Time is everywhere in cybersecurity research" according to Tim Stevens [22]. I have described the antecedent conditions and the consequences of cybersecurity conflicts over time. Furthermore, my theory incorporates a cyclical approach to time, given that cybersecurity incidents occur again, and again, and again. One key observation that resulted from my research is how much time can expend before key behaviors occur when addressing data breaches. In my pilot case study, which occurred in early 2021, major regulatory enforcement did not occur until late in 2025. For followers of regulatory compliance, this timeline is seen as nominal, but for investigating real-world cases, this can put a strain on the research process.

There was a consistent pattern of litigation in all cases except for one. This rights-based effort for conflict management may seem like an obvious response, but it presents some important factors for discussion. First, the overwhelming use of lawsuits after data privacy incidents demonstrates a crucial method for affected users to get compensation, but also to try to punish companies for failures. Furthermore, regulators also contribute to litigation against companies for cybersecurity failures. Successful lawsuits in these cases can lead to

modest cash payments to users, but taken together, and along with fines, they can be costly for the software producers. More broadly, it demonstrates that there may not be other methods for users to manage data privacy and security conflicts with software companies, such as through interest-based negotiation. That being said, it is clearly impractical to bring thousands or even millions of users to the negotiating table, which is precisely why class action lawsuits exist. It is also why regulators have a role in suing software producers for violations.

Another consistent behavior was the offer of identity theft and credit monitoring services by the software producers after the breach. While they frequently provided this prior to any litigation, it was also often included in settlement agreements. Contrary to the rights-based approach of litigation, the monitoring service offer represents some interest-based approaches to managing the dispute. By providing these tools the software producer acknowledges that the data breach could have an effect on affected users, particularly through financial crimes, and identity theft/credit monitoring can help meet their needs.

Another set of patterns described explicitly in the model are the posturing efforts undertaken by all stakeholders. Users connected with legal representatives, data privacy advocates, and other civil society organizations to speak publicly about the harms they suffered, and to support their interests in getting compensated. Regulators released statements, worked with cybersecurity experts, implemented nonbinding rules, and threatened legal actions to support enforcement. Software producers also made public statements, although they also postured by limiting publicly available information. These efforts seem like a natural response to managing data privacy conflicts, although their effectiveness varied in each case. Regardless of the outcomes in the cases, the more posturing activities that were undertaken, the higher the costs were, because it takes resources to make these efforts. A noteworthy example of this was Illuminate Education's approach to posturing through concealment. Specifically, they sealed court documents, which would have added extra costs

and (potentially substantial) work for their legal team.

The data, specifically Findings 2,4, and 5, showed that behaviors that led to the best outcomes for the users over the course of a case were strict regulatory regimes prior to an incident, as well as active enforcement activities by regulators and active compliance activities by the software producers after the incident. This was demonstrated primarily in the Equifax case, when users received the largest compensation package out of all the cases I analyzed. Further analysis of other data privacy litigation that resulted in compensation for users, such as those in [29, 50], which include analysis of dozens of such lawsuits.

The other notable patterns were those that led to important changes for future cases, cases that had an observable Aftermath phase (Section 5.1.2) resulting from key transformations to regulations, as shown in Finding 5. In these cases, the unique combination of novel approaches to cooperation, the identification of gaps in enforcement mechanisms, and a shared perception of the critical nature of the data that was compromised led to changes in the regulatory, threat, and operational environments for stakeholders going forward. When stakeholders were able to capitalize on these trends, they were able to work together to improve data security and privacy to meet their mutual interests. This has positive impacts on commerce, security, and well-being for all parties involved. This is a key insight from my research, that for lasting impacts to occur from a single case, there must be new methods of cooperation. This occurred in three cases, and, taken together with other factors, led to crucial impacts on data privacy and security. These examples were unique in each case, and did not always include all the stakeholders.

As a caveat, the other two factors connected to disruptive aftermaths, gaps in enforcement methods and a perception of the critical nature of the compromised data, are not always discernible or actionable while a case is unfolding. For example, one group may think that the compromised data may be critical, but others may not. Or, stakeholders may not be able to pursue new methods of enforcement for a variety of reasons. Regardless, un-

derstanding that the combination of these three factors might lead to critical changes to data privacy and security protections is important for stakeholders so that they can seek them out when possible to make change, and retrospectively observe them so they understand how the change came about.

6.3 RQ3: How can cooperation between these stakeholders be facilitated?

The theory and model I have developed may be useful in facilitating cooperation between stakeholders before and after data breaches. As a model of the system of behaviors and outcomes in cybersecurity breaches, practitioners and researchers can better identify their options to achieve the best outcomes. They can do this both before and after incidents occur. In particular, the four categories of behaviors undertaken by all stakeholders following an incident are posturing, compensating, correcting, and complying. These categories are parallel for each stakeholder because they reflect the shared concerns that each has after a cybersecurity incident. While their actual behaviors within those categories differ based on their roles and their interests, this symmetry still demonstrates opportunities for cooperation. Given that the theory of regulate, recover, repeat is cyclical in nature, these responses are also preludes to future conflicts.

Prior to an incident, stakeholders can use the model to analyze their current status, as well as look at existing cases in similar contexts to determine what they are doing that could set them up for success or failure if and when a breach occurs. In Finding 3, I described the ways that users in particular can build their own capacity in advance of data breaches. Some aspects of this are already occurring, such as the lawyers at the software producer being familiar with the regime in place. Another example is that stakeholders should be aware of the advocacy organizations that represent the users in the industry they are in, and have open lines of communication with them.

After an incident, stakeholders can use the model to look at what the net effects may be of any of their behaviors and those of the other stakeholders. The model is especially practical in this area as the behaviors and outcomes for each stakeholder are in nearly identical categories. This makes it easy for any stakeholder to understand the relationship between their actions and the others'. As described in Finding 5, it is possible for stakeholders to consider the transformations resulting from the incident to determine whether broader changes are possible, or necessary.

One area where cooperation can be facilitated is improving the capacity of all stakeholders to address data privacy and security. In the model, each stakeholder has a certain level of capacity, based on a variety of factors. Capacity is also documented as a characteristic that can improve cybersecurity in other research [1, 26]. Capacity is frequently driven not by any one stakeholder, but by relationships with other parties that help improve their capacity. For example, users are often represented by advocacy groups that provide training and resources, among other things. For software producers and regulators, this capacity is often supported by external cybersecurity vendors, including technical and legal experts. It is likely that these different expert resources have some connections to each other, such as through industry conferences, but facilitating open relationships between them and their clients could help improve outcomes. For example, in the Equifax case, one of the advocacy organizations was US PIRG, which represents consumers in a variety of ways. Equifax and federal regulators had a relationship with cybersecurity company Mandiant to help reinforce their cybersecurity. Together, organizations like organizations could help build capacity for all stakeholders. Privacy advocacy groups likely maintain such connections with cybersecurity firms, but there also may be more adversarial relationships between actors, such as privacy advocates and large software companies, when they do not perceive their interests to be in alignment. By coordinating their efforts, they may be able to improve security through a united front, and seeking new solutions. This

was demonstrated in the CatalanGate case, when privacy advocates cooperated with Meta on the lawsuit against NSO Group. While normally that relationship is strained, the novel cooperation helped improve outcomes.

One way to support this type of coordination could be through conferences. Disparate stakeholders, even those who feel uninitiated in cybersecurity, can still find opportunities to develop coagency in these settings. James Shires describes cybersecurity conferences as "ritualized activities" that can help create "expert community across international boundaries despite significant political and social differences" [83]. Finding new ways for stakeholders to cooperate could be instrumental in supporting data privacy and security. Shires goes on to say that "cybersecurity expertise should not be thought of as a gap to be closed, because the requirements for successful performance grow together with the widening of the domain." As the threat to users, software producers, and regulators continues to be a problem, there must be new modes of cooperation to support their mutual interests.

Another example of the cooperation appears in research on collective action for remediating data privacy breaches. Wu, Edwards, and Das developed a concept using "Find-Fix-Verify" to help coordinate demands among disparate users that were affected by data breaches and other "privacy-violating institutional experiences" [100]. In their research, they used this process to "[simplify] the complex task of asynchronously distilling a unified set of demands from a distributed collective" using two of the same cases in this dissertation, Equifax and OPM. The results were somewhat vague lists of demands, but the authors noted that this could be improved by incorporating experts to help "steward" the process [100].

In Section 2.1.2, I described cooperation as akin to a puzzle box, where looking at a jumble of pieces was not always enough to see the possible outcome. Instead, we rely on the final picture to help us assemble the pieces into a whole. Facilitating cooperation in cybersecurity is much the same, and the results of my research are designed to provide

such a picture to stakeholders. While the patterns of conflict management discussed above regarding RQ2 are likely to be well known, the methods of facilitating cooperation in RQ3 are not. Now, stakeholders involved in data privacy and security have a clearer picture of what cooperation can look like in the field and for future research.

6.4 Relationship to the Literature

My grounded theory and my model were built from the empirical evidence that I observed. However, there are many models in cybersecurity, conflict analysis, international relations, and other fields that are related to my results. Many of these were included in the introduction, and I will include some of them again here. The final model does not preclude the use of other models in analyzing real-world scenarios. In fact, many align very well, and can be used in conjunction with each other for both research and applied purposes. As I discussed in my methodology (Section 3.4) I used "constant comparison" to challenge my emergent findings with other theories and additional literature [27, 40, 86].

The best example is the NIST Cybersecurity Framework (CSF), which "provides guidance to industry, government agencies, and other organizations to manage cybersecurity risks" [64]. This artifact, and its earlier versions, is a highly regarded resource that is freely available to organizations to support their cybersecurity. If my model did not mesh with an important model like the CSF, that would raise some concerns about the validity and applicability of my research. The CSF fits perfectly into the operating, and response, recovery, and remediation phases of my model, particularly for the software producers, who are likely to use the CSF, or something very similar, to inform their cybersecurity practices. However, the CSF is not designed to explain the relationship between the software producer and other stakeholders as a system. Additionally, it is not practical for an outside observer to use the CSF to investigate the broader conflicts that arise from a data breach over time.

Another model that integrates well is the "interests, rights, power" framework [91] that can be used to describe the different approaches that stakeholders took in addressing the conflicts. While there are various examples of these different approaches across the cases, I will select a few that best represent the framework. The interest-based approach to negotiating describes a process where the parties highlight their concerns and underlying needs to manage a conflict. This approach is represented by Equifax, and other software producers, when they provide credit monitoring services free of charge to their affected users. This effort aligns with the interests of all the stakeholders: it provides a remedy for users whose data was compromised, it demonstrates the software producers' interest in minimizing the harm to their users, it could help reduce penalties by regulators, and it meets regulatory interests by demonstrating a sort of deference by the company for a potential violation. However, as with many interest-based approaches, this was often not enough to resolve the dispute. The rights-based approaches are clear cut; the litigation efforts by the stakeholders in most of the cases are examples of the rights-based approach. In those cases where lawsuits were filed, and where the software producers did not settle outright, each stakeholder demonstrated that they thought they would prevail on a legal basis. Both the interest- and rights-based approaches clearly fit into the compensation, correcting, and complying behaviors after the incident in my model. The power-based approach was mostly apparent in some of the posturing behaviors. One example of this is in the Equifax case when members of Congress proposed legislation to penalize the company for the breach. As described in the case study, many of these bills did not go very far, and were clearly meant to coerce Equifax to take some action.

One model that I used early on to help describe the cases that had impactful aftermaths was Kello's Virtual Weapon [45]. In particular, his description of "systemic disruption" in which there has been a major disturbance that "disrupts the conduct of units" such as governments and software companies, including impacts on "rules, norms, and principals"

between non-state actors due to cyber attacks. The elements of his model aptly described the critical nature of the outcomes in the Illuminate Education, CatalanGate, and OPM cases, which resulted in disruptions to rules and norms.

While investigating the multiple roles of regulators as stakeholders, my research was complemented by analysis of multistakeholder governance from Marsden [55]. He describes the relationships between governmental and nongovernmental regulators in data privacy and security, including self-regulation by industry groups, co-regulation through an independent party with government support, and statutory regulation by government regulators. This spectrum, which was based on prior research, supported my empirical description of the different regulators involved in each case. This research helped reinforce, for example, my useful yet confusing model component, "Regulator Regulatory Context." In fact, he describes an equally perplexing example of "regulated self-regulation" which helps demonstrate how confusing this particular schema really is.

Throughout the constant comparison and grounded theory processes there were many other models that I examined in light of my emerging findings which aligned well, and at a minimum had no major contradictions. Many of these were included in the Background (Section 2), and in the dissertation proposal. There were others that I investigated later as well. These included Stakeholder Theory [32, 62], Privacy-by-Design [15], usable security and privacy [33], a taxonomy of cyber-harms [5], social contracts and privacy [56], and cybersecurity economics [31].

6.5 Limitations

Below I will address the major limitations of my research. As an interdisciplinary, qualitative study, analyzing real-world cases, there were many opportunities to pursue, but that had to be skipped due to limited resources. I hope to take advantage of the data and

the grounded theory in future research to address some of these areas of interest.

6.5.1 Case Selection

The first limitation was in my selection of cases to analyze. I focused entirely on data privacy and security conflicts, which provided a practical bound for a dissertation. However, selection of other types of cases may have resulted in a different, but also valid, grounded theory. Alternatively, choosing a wider variety of cases could have improved external validity.

The first example is avoiding analysis of militarized data breaches from the perspective of intelligence, espionage, or warfare. The use of cyberspace for warfighting operations is important and has broader impacts on social conflict, as attacks on critical infrastructure, for example, have resounding effects for everyday people, not just militaries and not just in warzones. Some of my cases did include issues of security and physical conflict, such as the ICRC and CatalanGate cases. However, expanding my data to include the laws of war as regulations would have been a drastic and impractical jump. Additionally, it may have been difficult to get reliable data for analysis.

Another type of case that I avoided categorically was ransomware. While ransomware cases are typical of data privacy breaches, my attention was continuously brought to major cases where data was known to be compromised, resulting in more direct impacts to users beyond service interruptions. While there are examples of ransoms not being paid, [93], this primarily results in the loss of data with no backups, not exfiltration and potential privacy violations. Furthermore, introducing ransomware would have also implicated the attackers as stakeholders, adding complexity to the research that was outside the scope of my initial proposal. This might have included concepts around criminology and negotiation that would have been difficult to pursue. However, incorporating ransomware cases would

also be an obvious area to test the theory going forward. Crucially, the impact on all stakeholders does seem to fit into my grounded theory, for example, the correcting behaviors in the model, which describe e.g. addressing the loss of services or data after an attack. Insofar as data privacy and security impacts commerce, the consequences for businesses and governments that suffer ransomware attacks, and their constituent users, would be a logical area to pursue further research using my theory and model. An obvious example would be the dynamics between all stakeholders when determining how to approach resolving the issues caused by the ransomware, such as negotiating with the attackers, which seem quite different from recovering from data privacy violations.

6.5.2 Methods

There were two methodological limitations that could impact the theory, but that also provide space for future research. These do not limit validity (e.g. construct or internal validity) in any major way, but further investigation could help support the results, and would provide valuable knowledge for analyzing these cases, and demonstrate how the theory could be applied in the future. The first concerns data collection about the attackers, and technical details about their attacks. The second limitation is in regard to the use of the value scales to quantify the behaviors in each phase of a case.

First, I omitted details about the hackers and technical details about the breach from the theory and model. This was an explicit decision which allowed me to stay focused on the primary stakeholders I outlined in the proposal, and especially their behaviors and interactions. The advantage is that the theory can be agnostic to different types of breaches going forward, such as ransomware discussed above. Instead of analyzing the who, what, and why of the actors behind the breaches, which could be anyone at any time, I was able to investigate the people and organizations that suffer from these attacks, how they prepare,

and how they recover from them. Understanding the motives of hackers, while important, would not have yielded valuable data for these stakeholders, since there is little they can do to address them. Furthermore, gathering data on these motives would be impractical, given that these are deliberately surreptitious attackers, and even simple attribution can be near impossible at times. Technical details about the attacks were included in the case analyses, and these can be important for understanding the unaddressed failures and weaknesses that preempted the attacks. However, technical cybersecurity models, like NIST CSF, and others, have more practical tools for addressing these issues. Instead, the theory focuses on the broader precursors that led to these failures, and their impacts. Furthermore, the outcomes of these breaches in each case were often quite similar, regardless of the technical characteristics: there was unauthorized access to data, which resulted in the privacy of users being violated. This congruency is captured by the theory.

After analyzing the cases, I introduced value scales to provide a limited quantitative measure of the behaviors of each stakeholder at each phase of a case. For example, a Regulator may have been "Strict" or "Lenient" in Enforcement activities, or the Compensation for Users could have been "Unfavorable" or "Favorable." The primary limitation with this is that I only applied it generally to a high level grouping of the stakeholders, and not to other groups or individuals within the hierarchy. For example, Federal Regulators may have been "Strict" while State Regulators may have been "Neither Lenient Nor Strict" resulting in an overall value of "Somewhat Strict." Or, Business Customer Users may have had "Somewhat Favorable" Compensation while end users may have had "Somewhat Unfavorable" compensation. This resulted in some less accurate quantification of the behaviors and outcomes in the cases. However, adding this level of granularity would have roughly tripled the number of data points in each case, making it impractical to analyze as a sole researcher. Additionally, in the many cases where there were not differences among different levels of stakeholders, differentiating among them would have added unnecessary noise. I

accounted for the issue in two ways. First, I prioritized the qualitative data that I collected to develop the theory, and did not overly rely on the values; the description of what happened always took precedence. Additionally, when using the values for my analysis, I still analyzed the more granular characteristics, such as individual behaviors, to make sure my results were reliable. Furthermore, I did not use these values for any additional quantitative analysis, although future statistical applications would be a valuable area to pursue.

In reality, the stakeholders included in the model (users, regulators, software producers) are groups of stakeholders in the case, not just standalone actors. It is practical to group them together at a high level early on, and more useful to break them down further when analyzing a given case. Frequently, this breakdown results in a hierarchy of different stakeholders within each group. It is not always practical to ascertain a clear, distinct value for where they sit in the hierarchy, but there is often some logical inference about where they sit compared to others in their group, and compared to other stakeholder groups in terms of relative power. Analyzing the different stakeholders within each group in terms of a hierarchy is extremely useful for understanding the conflict and cooperation within the case. This structure could be useful in future research.

Another limitation of this value scale, and the overall qualitative approach, is in the area of costs for stakeholders in each case. It would be great to have detailed quantitative monetary values for analysis. However, it is not always feasible to get reliable information about how much was spent on cybersecurity before or after each case, how much an incident cost a company, how much regulators spent on enforcement, or the legal fees for lawsuits. There are, for example, calculators to estimate the cost of a data breach, such as one from At-Bay, which I used and referred to in the full case studies. But they can have different results, and may not include all factors. There was occasionally publicly reported data, such as from government investigations, mandated financial reports, and court documents, and I was able to observe general expenditures. However, even when I could collect

this information, the cases were so different that comparing dollar-for-dollar costs was not useful. Furthermore, even without publicly reported information, I was still able to infer costs. For example, large investigations with major reports and staff, such as the PEGA Committee in CatalanGate, can reasonably be assumed to have been quite costly. As such, it was more reliable to provide my own values for cost data, leading to broad scores like "low" and "high" which could be easily verified, and made it possible to compare between dissimilar cases.

6.5.3 On Being WEIRD

One obvious limitation is the setting for my data, which is predominantly WEIRD: Western, Educated, Industrialized, Rich, and Democratic, a known issue in security and privacy research, and beyond [22, 38]. The reality is that the data I aimed to analyze, including company reports, government investigations, and other publicly available artifacts, are primarily "based in the West" which was a primary factor in my "focus on a limited number of Western countries where research-enabling data is easier to access" [22]. Furthermore, choosing cases among other "rising cyber powers (e.g. India, Brazil, or South Korea)," [22] would have also required a substantial burden in my research. Understanding the regulatory regimes and business practices in the US and Europe was already a major challenge, despite my familiarity with them, and ready access to resources, including subject matter experts. Attempting to analyze the intricacies of cases in other countries would have been insurmountable for a dissertation.

However, there is a critical approach to my research that supports validity regardless of the WEIRD limitations. The goal of my dissertation is to "challenge, transform, and empower" and directly addresses the "current distribution of power" in society [90]. Because of this, my grounded theory can contribute to knowledge production that is not simply

Western- or state-centric, as it has been designed to address "cybersecurity as a lived experience" and incorporates the way various stakeholders interact [22]. Future research can use the theory and model to elucidate issues in other countries and among marginalized populations, not just in the environments included in my case selection. Furthermore, my use of grounded theory methods also provides a foundation for growth to improve the data to address a wider space of multistakeholder cybersecurity.

Lastly, I will point out that I attempted to include more global data through the ICRC case, which had affected users spread across the world. However, I will concede that the data in that case did not contribute substantially to future research in non-Western scenarios.

Chapter 7: Conclusion

This research uses grounded theory and case studies to investigate the relationships between stakeholders in data privacy and security, including software producers, regulators, and users. By examining five real-world cases of conflict between these groups, caused by a data breach, the results include a grounded theory and model of cybersecurity conflict and cooperation behaviors and outcomes. The theory and model can be used by practitioners and researchers to investigate past, present, and future cases to understand the systems of software security.

The objective of my dissertation was to create practical framework for understanding the systems of actors and actions in data privacy and security. My goal was to help make it easier for a broad spectrum of software security practitioners and researchers to understand cybersecurity conflicts both in the past and as they unfold. This can include engineers, regulators, academics, leaders, business people, and lay users. To do this, I investigated five different systems and preeminent conflicts that occurred within them. I analyzed these five cases, including their stakeholders, behaviors, antecedents, and outcomes, for the similarities and differences between them to develop a comprehensive model and theory. Now these tools can be applied by software security professionals, broadly defined, to interpret and improve outcomes.

Future research can use my data and results in a variety of ways. Expanding on the quantitative characteristics of stakeholder's behaviors could help redefine expectations when they pursue a particular course of action. For example, when comparing the cost of

building cybersecurity capacity with the risks of litigation in their particular industry. Another area of investigation would be testing the model with professionals in the field. This could include bringing together a heterogeneous group of technical, legal, and management professionals in a controlled setting, introducing them to the model, and seeing how they would use it to collaborate in a hypothetical scenario. Lastly, researchers can use the model in further cybersecurity research to situate their data and ensure they have covered all factors that might affect their results.

I was able to conduct such extensive research on these cases in large part due to the availability of reliable information from civil society and government actors. Given the applied and critical nature of the research, it is my hope that these same actors will use my data and results in their efforts to improve data privacy and security for their constituents. They have new, actionable insights on complex relationships, including empirical data on how cooperation between stakeholders can support their work. At times, this may even involve reshaping power dynamics to support people who may be disproportionately affected by data breaches. While businesses are not always as forthcoming with the details of their cybersecurity tribulations, in these cases, there was still valuable data from them, whether it was voluntary or mandated. Regardless, they too can use my results to support their software security efforts, no matter what field they are in. Ultimately, I hope that all these stakeholders can work together using my results as a collaborative resource to improve cybersecurity outcomes.

Bibliography

[1] The cybersecurity capacity maturity model for nations (cmm). https://gcscc.web.ox.ac.uk/the-cmm. Accessed: 2023-04-06.

[2] Mission, team, and story - the algorithmic justice league. https://www.ajl.org/about.

[3] The logical framework. Technical report, USAID, 2012.

[4] Alessandro Acquisti, Laura Brandimarte, and George Loewenstein. Privacy and human behavior in the age of information. *Science*, 347(6221):509–514, 2015.

[5] Ioannis Agrafiotis, Jason RC Nurse, Michael Goldsmith, Sadie Creese, and David Upton. A taxonomy of cyber-harms: Defining the impacts of cyber-attacks and understanding how they propagate. *Journal of Cybersecurity*, 4(1):tyy006, 2018.

[6] Najd Alfawzan, Markus Christen, Giovanni Spitale, and Nikola Biller-Andorno. Privacy, data sharing, and data security policies of women's mhealth apps: Scoping review and content analysis. *JMIR mHealth and uHealth*, 10(5):e33735, 2022.

[7] Laurence Ashworth and Clinton Free. Marketing dataveillance and digital privacy: Using theories of justice to understand consumers' online privacy concerns. *Journal of business ethics*, 67:107–123, 2006.

[8] Brooke Auxier, Lee Rainie, Monica Anderson, Andrew Perrin, Madhu Kumar, and Erica Turner. Americans and privacy: Concerned, confused and feeling lack of control over their personal information. *Pew Research Center*, 2019.

[9] Steven Bellman, Eric J Johnson, Stephen J Kobrin, and Gerald L Lohse. International differences in information privacy concerns: A global survey of consumers. *The Information Society*, 20(5):313–324, 2004.

[10] Raymond Bierens, Bram Klievink, and Jan van Den Berg. A social cyber contract theory model for understanding national cyber strategies. In *Electronic Government: 16th IFIP WG 8.5 International Conference, EGOV 2017, St. Petersburg, Russia, September 4-7, 2017, Proceedings 16*, pages 166–176. Springer, 2017.

[11] Michael Böcher. A theoretical framework for explaining the choice of instruments in environmental policy. *Forest Policy and Economics*, 16:14–22, 2012.

[12] Barry W Boehm and Philip N. Papaccio. Understanding and controlling software costs. *IEEE transactions on software engineering*, 14(10):1462–1477, 1988.

[13] Lisa Bowleg. The problem with the phrase women and minorities: intersectionality—an important theoretical framework for public health. *American journal of public health*, 102(7):1267–1273, 2012.

[14] Ian Brown and Christopher T Marsden. *Regulating code: Good governance and better regulation in the information age*. MIT Press, 2013.

[15] Ann Cavoukian. Privacy by design. *Office of the Information and Privacy Commissioner*, 2009.

[16] Kathy Charmaz. *Constructing grounded theory*. sage, 2014.

[17] Mitchell Chris. *The Structure of International Conflict*. Macmillan, London, 1981.

[18] Richard Alan Clarke and Robert K Knake. *The fifth domain: Defending our country, our companies, and ourselves in the age of cyber threats*. Penguin Press, 2019.

[19] Jason A Colquitt, Donald E Conlon, Michael J Wesson, Christopher OLH Porter, and K Yee Ng. Justice at the millennium: a meta-analytic review of 25 years of organizational justice research. *Journal of applied psychology*, 86(3):425, 2001.

[20] Lewis A Coser. *The functions of social conflict*, volume 9. Routledge, 1998.

[21] Sadie Creese, William H Dutton, Patricia Esteve-Gonzalez, and Ruth Shillair. Cybersecurity capacity-building: cross-national benefits and international divides. *Journal of Cyber Policy*, 6(2):214–235, 2021.

[22] Fabio Cristiano, Xymena Kurowska, Tim Stevens, Louise Marie Hurel, Noran Shafik Fouad, Myriam Dunn Cavelty, Dennis Broeders, Tobias Liebetrau, and James Shires. Cybersecurity and the politics of knowledge production: towards a reflexive practice. *Journal of Cyber Policy*, 8(3):331–364, 2023.

[23] Mary J Culnan and Robert J Bies. Consumer privacy: Balancing economic and justice considerations. *Journal of social issues*, 59(2):323–342, 2003.

[24] Peter DeGrace and Leslie Hulet Stahl. *Wicked problems, righteous solutions*. Yourdon Press, 1990.

[25] Mina Deng, Kim Wuyts, Riccardo Scandariato, Bart Preneel, and Wouter Joosen. A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements. *Requirements Engineering*, 16(1):3–32, 2011.

[26] William H Dutton, Sadie Creese, Ruth Shillair, and Maria Bada. Cybersecurity capacity: does it matter? *Journal of Information Policy*, 9:280–306, 2019.

[27] Kathleen M Eisenhardt. Building theories from case study research. *Academy of management review*, 14(4):532–550, 1989.

[28] European Parliament and Council of the European Union. Regulation (EU) 2016/679 of the European Parliament and of the Council.

[29] Ellis Fenske, Christopher W Brown, and Jeff Kosseff. Courting consensus: How class action lawsuits shape data privacy rights and obligations in the us. In *Proceedings of the 23rd Workshop on Privacy in the Electronic Society*, pages 172–185, 2023.

[30] Simon Fisher, Jawed Ludin, Dekha Ibrahim Abdi, Richard Smith, Steve Williams, and Sue Williams. *Working with conflict: Skills and strategies for action*. Zed books, 2011.

[31] Anderson Frailey. The effects of privacy regulation on the supply of stolen data. 2025.

[32] R Edward Freeman. *Strategic management: A stakeholder approach*. Cambridge university press, 2010.

[33] Simson Garfinkel and Heather Richter Lipford. Usable security: History, themes, and challenges. *Synthesis Lectures on Information Security, Privacy, and Trust*, 5(2):1–124, 2014.

[34] Robert Gellman. Fair information practices: A basic history. *Available at SSRN*, 2415020, 2017.

[35] António Guterres. Roadmap for digital cooperation. *United Nations. June*, 2020.

[36] Foad Hamidi, Kellie Poneres, Aaron Massey, and Amy Hurst. Who should have access to my pointing data? privacy tradeoffs of adaptive assistive technologies. In *Proceedings of the 20th international acm sigaccess conference on computers and accessibility*, pages 203–216, 2018.

[37] Geir K Hanssen. A longitudinal case study of an emerging software ecosystem: Implications for practice and theory. *Journal of Systems and Software*, 85(7):1455–1466, 2012.

[38] Ayako A Hasegawa, Daisuke Inoue, and Mitsuaki Akiyama. How {WEIRD} is usable privacy and security research? In *33rd USENIX Security Symposium (USENIX Security 24)*, pages 3241–3258, 2024.

[39] Richard Hill. The internet, its governance, and the multi-stakeholder model. *Info*, 16(2):16–46, 2014.

[40] Rashina Hoda. Socio-Technical Grounded Theory for Software Engineering. *IEEE Transactions on Software Engineering*, 48(10):3808–3832, October 2022.

[41] Jennifer Yang Hui. Social media and the 2019 indonesian elections. *Southeast Asian Affairs*, pages 155–172, 2020.

[42] Chris Inglis and Harry Krejsa. Thee cyber social contract: How to rebuild trust in a digital world. *Foreign Affairs*, 2022.

[43] International Committee of the Red Cross. Assessing restoring family links needs: Handbook for national societies and the icrc, 2010.

[44] Karen A Jehn. A qualitative analysis of conflict types and dimensions in organizational groups. *Administrative science quarterly*, pages 530–557, 1997.

[45] Lucas Kello. *The virtual weapon and international order*. Yale University Press, 2017.

[46] Méabh Kenny and Robert Fourie. Contrasting classic, straussian, and constructivist grounded theory: Methodological and philosophical conflicts. *The Qualitative Report*, 20(8):1270–1289, 2015.

[47] Young Mie Kim, Jordan Hsu, David Neiman, Colin Kou, Levi Bankston, Soo Yun Kim, Richard Heinrich, Robyn Baragwanath, and Garvesh Raskutti. The stealth media? groups and targets behind divisive issue campaigns on facebook. *Political Communication*, 35(4):515–541, 2018.

[48] ERIKS KLOTINS, VESELKA BOEVA, KRZYSZTOF WNUK, and MICHAEL UNTERKALMSTEINER. A collaborative method for identification and selection of data sources in market-driven requirements engineering. 2019.

[49] M Audrey Korsgaard, Sophia Soyoung Jeong, Douglas M Mahony, and Adrian H Pitariu. A multilevel view of intragroup conflict. *Journal of management*, 34(6):1222–1252, 2008.

[50] Jeff Kosseff, Chris Brown, Ellis Fenske, and Don Needham. Not easily dismissed: The growing importance of data breach litigation in cybersecurity. *Boston University Journal of Science & Technology Law*, 30:189–222, 2024.

[51] Christopher Kuner. Reality and illusion in eu data transfer regulation post schrems. *German Law Journal*, 18(4):881–918, 2017.

[52] Stefan Laube and Rainer Böhme. The economics of mandatory security breach reporting to authorities. *Journal of Cybersecurity*, 2(1):29–41, December 2016.

[53] Anne L Lytle, Jeanne M Brett, and Debra L Shapiro. The strategic use of interests, rights, and power to resolve disputes. *Negotiation Journal*, 15(1):31–51, 1999.

[54] Konstantinos Manikas. Revisiting software ecosystems research: A longitudinal literature study. *Journal of Systems and Software*, 117:84–103, 2016.

[55] Christopher T Marsden. Beyond europe: The internet, regulation, and multistakeholder governance—representing the consumer interest? *Journal of Consumer Policy*, 31(1):115–132, 2008.

[56] Kelly D Martin and Patrick E Murphy. The role of data privacy in marketing. *Journal of the Academy of Marketing Science*, 45:135–155, 2017.

[57] Vivian B. Martin. Using Popular and Academic Literature as Data for Formal Grounded Theory. In *The SAGE Handbook of Current Developments in Grounded Theory*, pages 222–243. Sage Publications, Ltd, Thousand Oaks, CA, 2019.

[58] Thomas K McCraw. Regulation in america. *Business History Review*, 49(2):159–183, 1975.

[59] Gary McGraw. Software security. *IEEE Security & Privacy*, 2(2):80–83, 2004.

[60] Matthew B Miles, A Michael Huberman, and Johnny Saldaña. *Qualitative data analysis a methods sourcebook*. Thousand Oaks, Califorinia SAGE Publications, Inc., 2014.

[61] George R Milne and Mary Ellen Gordon. Direct mail privacy-efficiency trade-offs within an implied social contract framework. *Journal of Public Policy & Marketing*, 12(2):206–215, 1993.

[62] Ronald K Mitchell, Bradley R Agle, and Donna J Wood. Toward a theory of stakeholder identification and salience: Defining the principle of who and what really counts. *Academy of management review*, 22(4):853–886, 1997.

[63] Nabil M Mohammed, Mahmood Niazi, Mohammad Alshayeb, and Sajjad Mahmood. Exploring software security approaches in software development lifecycle: A systematic mapping study. *Computer Standards & Interfaces*, 50:107–115, 2017.

[64] Alex Nelson, Sanjay Rekhi, Murugiah Souppaya, and Karen Scarfone. Incident response recommendations and considerations for cybersecurity risk management: A csf 2.0 community profile. Technical Report NIST Special Publication (SP) 800-61r3, National Institute of Standards and Technology, Gaithersburg, MD, April 2025.

[65] Joseph S Nye et al. *The regime complex for managing global cyber activities*, volume 1. Belfer Center for Science and International Affairs, John F. Kennedy School, 2014.

[66] Marie Caroline Oetzel and Sarah Spiekermann. A systematic methodology for privacy impact assessments: a design science approach. *European Journal of Information Systems*, 23(2):126–150, 2014.

[67] Office of the Press Secretary. Presidential policy directive. Technical report, The White House, 2013.

[68] Kieron O'hara and Wendy Hall. Four internets. *Communications of the ACM*, 63(3):28–30, 2020.

[69] Cathy O'neil. *Weapons of math destruction: How big data increases inequality and threatens democracy*. Crown, 2017.

[70] Paul N Otto and Annie I Antón. Addressing legal requirements in requirements engineering. In *15th IEEE international requirements engineering conference (RE 2007)*, pages 5–14. IEEE, 2007.

[71] Leysia Palen and Paul Dourish. Unpacking" privacy" for a networked world. In *Proceedings of the SIGCHI conference on Human factors in computing systems*, pages 129–136, 2003.

[72] Jennifer Pinsof. Reproductive justice and digital rights: 2022 in review. *Electronic Frontier Foundation*, 2022.

[73] Institute Project Management. *A Guide to the Project Management Body of Knowledge (PMBOK® Guide) – Seventh Edition and The Standard for Project Management (ENGLISH).*, volume Seventh edition of *PMBOK® Guide*. Project Management Institute, 2021.

[74] Dean G Pruitt and Sung Hee Kim. *Social conflict: Escalation, stalemate, and settlement*. Mcgraw-Hill Book Company, 2004.

[75] William N Robinson. Integrating multiple specifications using domain goals. *ACM SIGSOFT Software Engineering Notes*, 14(3):219–226, 1989.

[76] Per Runeson and Martin Höst. Guidelines for conducting and reporting case study research in software engineering. *Empirical software engineering*, 14:131–164, 2009.

[77] Andrew L Russell. *Open standards and the digital age*. Cambridge University Press, 2014.

[78] Spyridon Samonas and David Coss. The cia strikes back: Redefining confidentiality, integrity and availability in security. *Journal of Information System Security*, 10(3), 2014.

[79] Paul Schwartz and Edward Janger. Notification of data security breaches. *Michigan Law Review*, 105(5):913–984, 2007.

[80] Carolyn B. Seaman, Rashina Hoda, and Robert Feldt. Qualitative Research Methods in Software Engineering: Past, Present, and Future. *IEEE Transactions on Software Engineering*, 51(3):783–788, March 2025.

[81] Jason Seawright and John Gerring. Case selection techniques in case study research: A menu of qualitative and quantitative options. *Political research quarterly*, 61(2):294–308, 2008.

[82] Elaine M Sedenberg and Deirdre K Mulligan. Public health as a model for cybersecurity information sharing. *Berkeley Tech. LJ*, 30:1687, 2015.

[83] James Shires. Enacting expertise: Ritual and risk in cybersecurity. *Politics and Governance*, 6(2):31–40, 2018.

[84] Daniel J Solove. A taxonomy of privacy. *University of Pennsylvania Law Review*, pages 477–564, 2006.

[85] Klaas-Jan Stol, Paul Ralph, and Brian Fitzgerald. Grounded theory in software engineering research: a critical review and guidelines. In *Proceedings of the 38th International conference on software engineering*, pages 120–131, 2016.

[86] Anselm Strauss and Juliet Corbin. *Basics of qualitative research*. Sage publications, 1990.

[87] Elliot Talbert-Goldstein. Integrative question for the doctoral comprehensive examination, 2022.

[88] Elliot Talbert-Goldstein, Yaxing Yao, and Carolyn Seaman. The role of the user in privacy regulation. Manuscript submitted for publication, 2026.

[89] National Telecommunications and Information Administration. Sbom at a glance. *NTIA Multistakeholder Process on Software Component Transparency*, 2021.

[90] Elizabeth J Tisdell, Sharan B Merriam, and Heather L Stuckey-Peyrot. *Qualitative research: A guide to design and implementation*. Jossey-Bass, 4th edition edition, 2016.

[91] William L Ury, Jeanne M Brett, and Stephen B Goldberg. Designing an effective dispute resolution system. *Negotiation Journal*, 4(4):413–431, 1988.

[92] Axel Van Lamsweerde, Robert Darimont, and Emmanuel Letier. Managing conflicts in goal-driven requirements engineering. *IEEE transactions on Software engineering*, 24(11):908–926, 1998.

[93] Jai Vijayan. Baltimore reportedly had no data backup process for many systems, 2019.

[94] Emily A Vogels. 56% of americans support more regulation of major technology companies. *Pew Research Center*, 20, 2021.

[95] Srdjan Vucetic. Genealogy as a research tool in international relations. *Review of International Studies*, 37(3):1295–1312, 2011.

[96] Daphne C Watkins. *Secondary data in mixed methods research*. SAGE Publications, 2022.

[97] Max Weber. Politics as a vocation. 1918. *From Max Weber: Essays in Sociology*, 1992.

[98] Andrew Whiting. Constructing cybersecurity. In *Constructing cybersecurity*, pages 126–49. Manchester University Press, 2020.

[99] Richard A Williams. Conflict propagation within large technology and software engineering programmes: A multi-partner enterprise system implementation as case study. *IEEE Access*, 7, 2019.

[100] Yuxi Wu, W Keith Edwards, and Sauvik Das. "a reasonable thing to ask for": Towards a unified voice in privacy collective action. In *Proceedings of the 2022 CHI Conference on Human Factors in Computing Systems*, pages 1–17, 2022.

[101] Robert K Yin. *Case study methods.* American Psychological Association, 2012.

[102] Laney Zhang. A guide to chinese legal research: Who makes what?, 2014.